



**FACULTAD DE POSTGRADO
TRABAJO FINAL DE GRADUACIÓN**

**FRAMEWORK UNIFICADO DE CIBERINTELIGENCIA DE
AMENAZAS (CTI) BASADO EN MITRE ATT&CK®,
GOBERNANZA DE DATOS ZERO TRUST Y SEGURIDAD
NACIONAL PARA LA PRIORIZACIÓN DE ACTORES DE
AMENAZA EN HONDURAS**

SUSTENTADO POR:

**EDER JOSUE ARTICA CRUZ
SUYAPA INES MATAMOROS PACHECO**

PREVIA INVESTIDURA AL TÍTULO DE

**MÁSTER EN
CIBERSEGURIDAD**

TEGUCIGALPA, FRANCISCO MORAZAN, HONDURAS, C.A.

JUNIO, 2026

**UNIVERSIDAD TECNOLÓGICA CENTROAMERICANA
UNITEC**

FACULTAD DE POSTGRADO

AUTORIDADES UNIVERSITARIAS

RECTORA

ROSALPINA RODRÍGUEZ

**VICERRECTOR ACADÉMICO NACIONAL
JAVIER ABRAHAM SALGADO LEZAMA**

SECRETARIO GENERAL

ROGER MARTÍNEZ MIRALDA

**DECANA FACULTAD DE POSTGRADO
ANA DEL CARMEN RETTALLY VARGAS**

**FRAMEWORK UNIFICADO DE CIBERINTELIGENCIA DE
AMENAZAS (CTI) BASADO EN MITRE ATT&CK®,
GOBERNANZA DE DATOS ZERO TRUST Y SEGURIDAD
NACIONAL PARA LA PRIORIZACIÓN DE ACTORES DE
AMENAZA EN HONDURAS**

**TRABAJO PRESENTADO EN CUMPLIMIENTO DE LOS
REQUISITOS EXIGIDOS PARA OPTAR AL TÍTULO DE
MÁSTER EN
CIBERSEGURIDAD**

**ASESOR
SERVIO PALACIOS**

MIEMBROS DE LA TERNA:

**NOMBRE COMPLETO EVALUADOR 1
NOMBRE COMPLETO EVALUADOR 2
NOMBRE COMPLETO EVALUADOR 3**

DERECHOS DE AUTOR

© Copyright 2023
Eder Josué Artica Cruz
Suyapa Ines Matamoros Pacheco

Todos los derechos son reservados.

**AUTORIZACIÓN DEL AUTOR(ES) PARA LA CONSULTA,
REPRODUCCIÓN PARCIAL O TOTAL Y PUBLICACIÓN
ELECTRÓNICA DEL TEXTO COMPLETO DE TESIS DE POSTGRADO**

Señores

**CENTRO DE RECURSOS PARA EL APRENDIZAJE Y LA INVESTIGACIÓN (CRAI)
UNIVERSIDAD TECNOLÓGICA CENTROAMERICANA (UNITEC)**

Estimados Señores:

Yo, XXXXXXXXXXXX, de Tegucigalpa, (o San Pedro Sula, o La Ceiba) autor del trabajo de postgrado titulado: XXXXXXXXXXXXXXXXXXXXXXXXXXXX, presentado y aprobado en XXXX, como requisito previo para optar al título de máster en XXXXXXXXXXXXXXXXXXXX y reconociendo que la presentación del presente documento forma parte de los requerimientos establecidos del programa de maestrías de la Universidad Tecnológica Centroamericana (UNITEC), por este medio autorizo a las Bibliotecas de los Centros de Recursos para el Aprendizaje y la Investigación (CRAI) de UNITEC, para que con fines académicos puedan libremente registrar, copiar o utilizar la información contenida en él, con fines educativos, investigativos o sociales de la siguiente manera:

- 1) Los usuarios puedan consultar el contenido de este trabajo en las salas de estudio de la biblioteca y/o la página Web de la Universidad.
- 2) Permita la consulta y/o la reproducción a los usuarios interesados en el contenido de este trabajo, para todos los usos que tengan finalidad académica, ya sea en formato CD o digital desde Internet, Intranet, etc., y en general en cualquier otro formato conocido o por conocer.

De conformidad con lo establecido en los artículos 9.2, 18, 19, 35 y 62 de la Ley de Derechos de Autor y de los Derechos Conexos; los derechos morales pertenecen al autor y son personalísimos, irrenunciables, imprescriptibles e inalienables. Asimismo, el autor cede de forma ilimitada y exclusiva a UNITEC la titularidad de los derechos patrimoniales. Es entendido que cualquier copia o reproducción del presente documento con fines de lucro no está permitida sin previa autorización por escrito de parte de UNITEC.

En fe de lo cual se suscribe el presente documento en la ciudad de _____, a los ____ días
del mes de _____ del año _____

Nombre completo

Número de cuenta

*** La autorización firmada se encuentra adjunta a mí expediente**



FACULTAD DE POSTGRADO

FRAMEWORK UNIFICADO DE CIBERINTELIGENCIA DE AMENAZAS (CTI) BASADO EN MITRE ATT&CK®, GOBERNANZA DE DATOS ZERO TRUST Y SEGURIDAD NACIONAL PARA LA PRIORIZACIÓN DE ACTORES DE AMENAZA EN HONDURAS

Eder Josué Artica Cruz
Suyapa Ines Matamoros
Pacheco

Resumen

[illegible]

Palabras claves: (xxxxx



GRADUATE SCHOOL

FRAMEWORK UNIFICADO DE CIBERINTELIGENCIA DE AMENAZAS (CTI) BASADO EN MITRE ATT&CK®, GOBERNANZA DE DATOS ZERO TRUST Y SEGURIDAD NACIONAL PARA LA PRIORIZACIÓN DE ACTORES DE AMENAZA EN HONDURAS

Eder Josue Artica Cruz
Suyapa Ines Matamoros
Pacheco

Abstract

XX
XX
XX
XX
XX
XX
XX
XX
XX
XX
XX

Palabras claves: (xxxxx)

DEDICATORIA

[illegible]

AGRADECIMIENTO

[illegible]

ÍNDICE DE CONTENIDO

DEDICATORIA.....	x
AGRADECIMIENTO.....	xi
ÍNDICE DE CONTENIDO.....	12
CAPÍTULO I. PLANTEAMIENTO DE LA INVESTIGACIÓN.....	14
1.1 INTRODUCCIÓN.....	14
1.2 ANTECEDENTES DEL PROBLEMA.....	15
1.3 DEFINICIÓN DEL PROBLEMA.....	16
1.3.1 Enunciado del problema.....	16
1.3.2 Formulación del problema.....	17
1.3.3 Preguntas de investigación.....	17
1.4 OBJETIVOS DEL PROYECTO.....	18
1.5 JUSTIFICACIÓN.....	18
1.6 CONTRIBUCIONES Y ALCANCES.....	20
1.7 LIMITACIONES.....	21
CAPÍTULO II. MARCO TEÓRICO.....	22
2.1 ANÁLISIS DE LA SITUACIÓN ACTUAL.....	22
2.2 CONCEPTUALIZACIÓN.....	22
2.3 TEORÍAS DE SUSTENTO.....	24
2.3.1 BASES TEORICAS.....	24
2.4 MARCO LEGAL.....	27
CAPÍTULO III. METODOLOGÍA.....	29
3.1 CONGRUENCIA METODOLÓGICA.....	29
3.1.1 MATRIZ METODOLÓGICA.....	30
3.1.2 ESQUEMA DE VARIABLES DE ESTUDIO.....	31
3.1.3 OPERACIONALIZACIÓN DE LAS VARIABLES.....	32
3.1.4 HIPÓTESIS.....	36
3.2 ENFOQUE Y MÉTODOS.....	36
3.3 DISEÑO DE LA INVESTIGACIÓN.....	37

3.3.1	POBLACIÓN.....	37
3.3.2	MUESTRA.....	37
3.3.3	TÉCNICAS DE MUESTREO.....	39
3.4	TÉCNICAS, INSTRUMENTOS Y PROCEDIMIENTOS APLICADOS.....	40
3.5	FUENTES DE INFORMACIÓN.....	41
3.5.1	FUENTES PRIMARIAS.....	41
3.5.2	FUENTES SECUNDARIAS.....	42
3.6	PIPELINE METODOLÓGICO Y DISEÑO DE SU ARQUITECTURA.....	42
3.7	ESTRATEGIA DE EVALUACIÓN.....	43
3.8	AMENAZAS A LA VALIDEZ.....	44
3.9	ÉTICA, PRIVACIDAD Y GOBERNANZA DE DATOS.....	45
CAPÍTULO IV. RESULTADOS Y ANÁLISIS.....		47
4.1	INFORME DE PROCESO DE RECOLECCIÓN DE DATOS.....	47
4.2	RESULTADOS Y ANÁLISIS DE LAS TÉCNICAS APLICADAS.....	51
4.2.1	RESULTADOS CUANTITATIVOS.....	51
4.2.2	ANÁLISIS CUALITATIVO.....	55
4.3	ANÁLISIS INFERENCIAL Y MODELOS APLICADOS.....	58
Bibliografía.....		61
ANEXOS.....		62
ANEXO A: Código de Automatización del Pipeline de Ingesta y Reglas Jerárquicas del SIEM.....		62
A.1 Script de Ingesta y Normalización Semántica (process_all_datasets_v3.py).....		62
A.2 Configuración de Reglas Jerárquicas en Wazuh (local_rules.xml).....		64
ANEXO B: Matriz de Auditoría Empírica de Telemetría y Alertas del SOC ($n=137$).....		66
ANEXO C: Catálogo Ontológico STIX 2.1 y Parametrización <i>FRSN</i> en OpenCTI.....		68
ANEXO D: Matriz de Correspondencia Prescriptiva MITRE ATT&CK® vs. MITRE D3FEND™.....		70
ANEXO E: Fichas Técnicas de Datasets Experimentales y Fuentes de Ciberinteligencia.....		73
E.1 Repositorios Públicos de Telemetría Experimental.....		73
1. Mordor Project (Open Threat Research):.....		73
E.2 Fuentes de Ciberinteligencia Táctica.....		74
ANEXO F: Diccionario de Datos y Normalización Semántica de Telemetría (Pipeline Zero		

Trust)	76
ANEXO G: Instrumentos de Recolección de Datos (Actividad 2.1).....	78
G.1 Instrumento 1: Plataforma de Orquestación OpenCTI, Mapeadores CSV (CSV Mappers) y Ficha de Ponderación CTI.....	80
G.2 Instrumento 2: Estándares Ontológicos (STIX 2.1), Protocolos TAXII 2.1 y Módulo de Certificación Zero Trust.....	81
G.3 Instrumento 3: Matrices Relacionales Taxonómicas (MITRE ATT&CK®, Attack Flow y MITRE D3FEND™ v1.4).....	83
G.4 Instrumento 4: Consola de Correlación de Eventos (SIEM).....	85
G.5 Instrumento 5: Plantilla Automatizada de Extracción de Métricas (Scripts Python) y Protocolo de Benchmarking.....	86

TABLA DE ILUSTRACIONES

Tabla 1: Matriz Metodológica de Alineación entre Título, Objetivos y Variables del Framework	30
Tabla 2: Matriz de Operacionalización de Variables Independientes y Dependiente del Framework.....	34
Tabla 3: Parametrización y Ponderación del Factor de Riesgo de Seguridad Nacional (FR_SN) 51	
Tabla 4: Evaluación Comparativa de Rendimiento en el SOC (Muestra n = 137).....	53
Tabla 5: Matriz de Correspondencia Táctica Defensiva (MITRE ATT&CK® vs. MITRE D3FEND™).....	56
Tabla 6: Contraste Metodológico frente a Modelos del Estado del Arte.....	58
Tabla 7: Estructura de la Muestra Auditada (Extracto de Muestra de 5 Registros Representativos)	66
Tabla 8: Fichas de caracterización ontológica de los ocho actores de amenazas modelados en OpenCTI bajo el estándar internacional STIX 2.1.....	68
Tabla 9: Matriz de Correspondencia Prescriptiva MITRE ATT&CK® vs. MITRE D3FEND™	70
Tabla 10: Matriz Resumen de Datasets Experimentales y Fuentes de Ciberinteligencia.....	74
Tabla 11: Diccionario de Datos y Normalización Semántica de Telemetría (Pipeline Zero Trust)	76
Tabla 12: Matriz de Alineación Metodológica: Objetivos, Variables e Instrumentos de Recolección.....	78
Tabla 13: Ficha Técnica de Parámetros CTI y Mapeador CSV para el Factor de Riesgo Nacional (FR_SN).....	80
Tabla 14: Mapeo Relacional Ofensivo-Defensivo basado en MITRE Attack Flow, ATT&CK® y D3FEND™.....	84
Tabla 15: Ficha de Registro de la Cámara de Observación (SIEM Log Audit) para la Muestra Auditada (n = 137).....	85

CAPÍTULO I. PLANTEAMIENTO DE LA INVESTIGACIÓN

1.1 INTRODUCCIÓN

El impacto global de la gestión de la ciberseguridad obliga a redirigir la mirada hacia el contexto local, donde las estrategias de defensa deben alinearse con las amenazas específicas y el entorno operativo en el que se desarrollan. En un panorama donde los incidentes de ransomware y las interrupciones a la Infraestructura Crítica Nacional (ICN) y los servicios esenciales van en aumento, ha quedado en evidencia que las defensas perimetrales estáticas son insuficientes. Si bien los Centros de Operaciones de Seguridad (SOC) buscan evolucionar hacia posturas proactivas mediante el consumo de Inteligencia de Amenazas Cibernéticas (CTI), se enfrentan a un desafío paralizante: la saturación y fragmentación de los reportes globales, un fenómeno documentado como la "cámara de eco" de la inteligencia de amenazas.

En el contexto hondureño, las organizaciones operan con recursos y presupuestos de ciberseguridad finitos, haciendo que su evaluación de actores de amenaza y enfoque de gestión de los insumos que estos puedan brindar a través de las capas de ciberseguridad y los diferentes eventos no estén siendo enfocados al contexto local y sí a enfoques globales, lo cual infiere en evaluaciones de riesgos sesgadas y posibilidades de impacto no acorde con la explotabilidad que actores de amenaza estén ejecutando. Sumado a esto, los modelos teóricos de evaluación de riesgo apoyados en el marco MITRE ATT&CK suelen fracasar en implementaciones reales al asumir un entorno con datos de auditoría perfectos. La realidad técnica de los SOC locales se caracteriza por la opacidad, la incompatibilidad de formatos de logs y un alto nivel de ruido en los eventos del sistema. Sin una correlación temporal adecuada y una limpieza previa, la inteligencia ingerida pierde su valor procesable.

Para resolver esta brecha, esta investigación propone una Metodología de Inteligencia de Amenazas (CTI) basada en MITRE ATT&CK y Gobernanza de Datos para la Priorización de Actores de Amenaza en Honduras. La arquitectura preanalítica se estructura en tres capas: 1) Gobernanza de logs en origen (NIST SP 800-207), 2) Ingesta en OpenCTI en formato STIX 2.1 / TAXII 2.1 integrando la telemetría de Group-IB Threat Intelligence y fuentes Estado/Nación (CISA/FBI) mediante un Factor de Riesgo Único de Seguridad Nacional ($\$FR_{\{\text{SN}\}}\$$), y 3) Secuenciación visual con MITRE Attack Flow y recomendaciones defensivas en MITRE

D3FEND™. Al fusionar modelos cuantitativos de riesgo con estrategias de normalización eficiente de registros en tiempo real, este trabajo establece un puente entre la inteligencia cruda y la detección operativa. Este enfoque permite a las organizaciones optimizar sus esfuerzos, enfocando sus capacidades de defensa exclusivamente en los adversarios que representan un peligro inminente y comprobado para la región.

1.2 ANTECEDENTES DEL PROBLEMA

La gestión analítica de la ciberseguridad en entornos operativos contemporáneos se enfrenta a una asimetría estructural entre la masividad de datos recolectados y la capacidad de respuesta táctica de los Centros de Operaciones de Seguridad (SOC). Históricamente, las organizaciones han priorizado el almacenamiento indiscriminado de registros lógicos (logs) bajo premisas perimetrales reactivas. Sin embargo, este enfoque induce a un colapso de capacidades conocido como fatiga de alertas. De acuerdo con las evidencias empíricas recolectadas por (Georgiadou et al., 2021), la proliferación de eventos anómalos benignos no correlacionados satura las pantallas de los analistas, lo cual degrada los tiempos de contención operativa y abre vectores críticos que facilitan movimientos laterales sofisticados.

El problema sistémico se agrava al evaluar el aprovisionamiento de Inteligencia de Ciberamenazas (CTI). Las plataformas analíticas convencionales ingieren flujos de datos comerciales globales provistos de forma genérica por los fabricantes. Tal como demuestran cuantitativamente (Suarez-Roman et al., 2026), el ecosistema actual de reportes de amenazas padece un severo efecto de cámara de eco (Echo Chamber Effect), caracterizado por la fragmentación, el solapamiento de indicadores atómicos y un profundo sesgo comercial que prioriza las dinámicas de ataques materializados en potencias industrializadas. Al contrastar este sesgo con el diagnóstico regional de (Pavón et al., 2022) sobre la brecha tecnológica y la disparidad de madurez en ciberdefensa de las economías latinoamericanas, se vuelve lógicamente imperativa la transición hacia un modelo metodológico capaz de calibrar el cálculo de riesgos probabilísticos en función del entorno geopolítico local, incorporando la telemetría regional de Group-IB y fuentes gubernamentales (CISA/FBI). El estado del arte analizado por (Yang et al., s. f.) señala que el modelado dinámico de Tácticas, Técnicas y Procedimientos (TTPs) fundamentado en marcos como MITRE ATT&CK es la ruta científica para neutralizar el comportamiento del adversario; no obstante, su viabilidad predictiva está intrínsecamente supuesta sobre la existencia de fuentes de

datos puras, íntegras y normalizadas en su origen, integrando herramientas de representación secuencial como MITRE Attack Flow y D3FEND™.

1.3 DEFINICIÓN DEL PROBLEMA

1.3.1 Enunciado del problema

La ausencia de un marco metodológico estandarizado que unifique el modelado dinámico y cuantitativo de Inteligencia de Ciberamenazas (CTI) adaptado al entorno geopolítico local —alimentado por Group-IB y conectores CISA/FBI en formato STIX 2.1/TAXII 2.1 con un Factor de Riesgo Único ($F R_{SN}$) —, con pipelines automatizados de Gobernanza de Datos que certifiquen y auditen la calidad de la telemetría en origen bajo principios Zero Trust, genera una persistente saturación analítica por falsos positivos y fatiga de alertas en los Centros de Operaciones de Seguridad (SOC) de las organizaciones en Honduras, lo cual degrada la precisión operativa de los motores de correlación, propicia una severa ceguera ante movimientos laterales de Amenazas Persistentes Avanzadas (APT) y expone de forma crítica e indefensa a las infraestructuras estratégicas, al cumplimiento normativo (Artículo 21 de la Resolución GE No. 342/2018 de la CNBS) y sectores financieros del entorno nacional frente a incidentes no contenidos de ciberdefensa.

1.3.2 Formulación del problema

¿De qué manera el diseño de una metodología que integre la Inteligencia de Amenazas basada en MITRE ATT&CK y un marco de gobernanza de datos permite al SOC priorizar de forma proactiva a los actores de amenaza de Ransomware en las organizaciones de infraestructura crítica en Honduras?

1.3.3 Preguntas de investigación

- ¿Cómo se pueden adaptar cuantitativamente las ecuaciones de probabilidad de ocurrencia geopolítica regional ($\$LO = II + RI + 0.2\$$) de Ahmed et al. (2022) al perfil de los adversarios activos en Honduras?

- ¿Qué componentes de control técnico debe incluir un framework de gobernanza de datos para certificar y normalizar semánticamente las fuentes de logs en origen, mitigando el ruido analítico en el SIEM?
- ¿De qué forma el modelado de grafos de ataque basados en la dimensión de "Access and Trust" de Georgiadou et al. (2021) permite predecir los movimientos laterales tácticos ante la ejecución de técnicas de Controls Override?

1.4 OBJETIVOS DEL PROYECTO

- **Objetivo General:**
 - Desarrollar una metodología analítica de Inteligencia de Amenazas (CTI) basada en MITRE ATT&CK y Gobernanza de Datos para optimizar las capacidades de priorización proactiva de actores de amenaza de Ransomware dentro de los Centros de Operaciones de Seguridad (SOC) en organizaciones de infraestructura crítica de Honduras.
- **Objetivos Específicos:**
- **Adaptar y calibrar cuantitativamente** el modelo matemático de probabilidad de ocurrencia geopolítica ($LO = II + RI + 0.2$) propuesto por Ahmed et al. (2022) al perfil táctico y motivacional de los adversarios de Ransomware activos en Honduras.
- **Diseñar un framework técnico** de gobernanza, normalización semántica y certificación de calidad para fuentes de logs en origen, mitigando el ruido analítico antes de la fase de correlación de eventos en el SIEM.
- **Modelar las trayectorias de riesgo y movimientos laterales** mediante la construcción de Grafos de Ataque dinámicos, evaluando la resistencia de los componentes de control de acceso exigidos por la norma NIST SP 800-207 frente a tácticas de evasión avanzada (*Controls Override*).

- **Evaluar el desempeño de la metodología unificada** mediante escenarios simulados de Ransomware avanzado para medir la reducción de la fatiga de alertas en el SOC.

1.5 JUSTIFICACIÓN

La presente investigación se justifica de manera multidimensional para responder a los retos críticos de seguridad informática y gobernanza que enfrentan las organizaciones que sostienen los servicios esenciales en Honduras.

Desde una justificación científica, este estudio aborda una brecha de conocimiento crítica detectada en la literatura internacional (Ahmed et al., 2022; Jiang et al., 2025). Los modelos matemáticos predictivos de amenazas globales asumen de forma idealista que los datos corporativos de entrada son homogéneos y perfectos. Esta investigación rompe ese paradigma y genera nuevo conocimiento al demostrar teórica y experimentalmente que la precisión analítica de las fórmulas de riesgo de ciberinteligencia depende de un marco previo de gobernanza que certifique el no repudio y la integridad de los logs en la fuente de origen.

En el ámbito de la justificación tecnológica, la metodología propone una innovación concreta: un framework de ingeniería de características (feature engineering) y normalización semántica automatizada para registros de auditoría. Esta herramienta dota a las infraestructuras de monitoreo tradicionales (SIEM) de capacidades avanzadas de filtrado de ruido y traducción algorítmica automatizada hacia técnicas de MITRE ATT&CK, permitiendo una automatización simétrica de la defensa.

Socialmente, la justificación social se fundamenta en la protección directa del Compromiso al Bienestar Humano (CHW) de la población hondureña. Sectores como energía, telecomunicaciones, banca y salud representan la espina dorsal del país; un ataque de Ransomware exitoso en estas infraestructuras no solo compromete datos confidenciales, sino que interrumpe la provisión de servicios públicos vitales. Esta tesis dota a la nación de un modelo metodológico soberano y geográficamente acotado para salvaguardar la estabilidad social.

Finalmente, la justificación económica responde a la necesidad de optimizar los recursos financieros en entornos con presupuestos restrictivos. Las organizaciones hondureñas no poseen el capital para competir contra las masivas inversiones tecnológicas de países desarrollados. Priorizar científicamente a los atacantes reales de la región permite al SOC enfocar sus inversiones de

respuesta y configuraciones analíticas exclusivamente en las amenazas de mayor probabilidad de impacto, disminuyendo drásticamente las pérdidas financieras directas (DFL) por paradas operativas no programadas y multas legales (LF), maximizando el retorno de inversión en ciberdefensa.

Para validar científicamente la viabilidad de la investigación y responder a las exigencias formalistas de posgrado, el sistema defensivo propuesto se define formalmente bajo los siguientes supuestos analíticos e invariantes de ingeniería:

Definición Formal del Sistema: Sea D el flujo total de telemetría y eventos lógicos ingerido por el Centro de Operaciones de Seguridad (SOC), tal que $D = D_p \cup D_r$, donde D_p representa el conjunto de datos semánticamente puros y conformes, y D_r representa el subconjunto de ruido estructural, registros degradados o alterados por técnicas de evasión de bitácoras (Controls Override).

Teorema I (Optimización Analítica del SOC). Si el motor de correlación lógica del SIEM procesa un flujo de datos D donde el coeficiente de ruido semántico en origen tiende al vacío ($D_r \rightarrow \emptyset$) a través de un pipeline automatizado de gobernanza que valida continuamente la telemetría, y las ecuaciones probabilísticas de Ocurrencia (LO, Likelihood of Occurrence) están calibradas para el entorno geográfico local mediante pesos deterministas ($LO = \llbracket II \rrbracket_{\text{Honduras}} + \llbracket RI \rrbracket_{\text{Honduras}} + 0.2$), entonces la Tasa de Falsos Positivos (TFP) del SOC disminuye monótonamente y la precisión analítica de los grafos de ataque tiende al 100%.

Corolario 1.1 (Axioma de Confianza Zero Trust). La fidelidad predictiva de una alerta de seguridad es inversamente proporcional a la entropía y degradación semántica de su fuente de origen. Ningún algoritmo matemático de Inteligencia de Ciberamenazas puede calcular un perfil de adversario válido si los registros de auditoría de los componentes violan el principio de verificación continua estipulado en la norma arquitectónica NIST SP 800-207.

1.6 CONTRIBUCIONES Y ALCANCES

Alcance del Proyecto: La investigación circunscribe su alcance técnico y operativo a la ciberdefensa de la Infraestructura Crítica Nacional (ICN) de la República de Honduras, abarcando sectores estratégicos como el financiero, energía, telecomunicaciones y servicios esenciales del Estado. En el plano tecnológico y de Ciberinteligencia de Amenazas (CTI), el alcance contempla:

1. La ingesta de telemetría regionalizada a través de la plataforma Group-IB Threat Intelligence y alimentadores oficiales Estado/Nación (CISA KEV y FBI InfraGard/FLASH) bajo el estándar STIX 2.1 / TAXII 2.1 centralizados en la plataforma OpenCTI.
2. El cálculo de priorización mediante un Factor de Riesgo Único de Seguridad Nacional ($F R_{SN}$), adaptado para Honduras a partir del modelo probabilístico de riesgo geopolítico.
3. La secuenciación temporal y visual de ataques mediante MITRE Attack Flow y la recomendación de contramedidas técnicas informativas mapeadas en el grafo MITRE D3FEND™.
4. La automatización de controles sintácticos para el cumplimiento de las pistas de auditoría exigidas por el Artículo 21 de la Resolución GE No. 342/2018 de la CNBS.

Alcance Experimental: La validación metodológica se circunscribe a un entorno de simulación controlado y aislado (Sandbox en Docker), fundamentado en la ingesta, normalización y validación analítica de casos de estudio dirigidos de actores APT (como FamousSparrow y campañas asociadas), evaluando la precisión en la atribución, el filtrado de ruido y la optimización de los tiempos de detección y respuesta en el SOC.

1.7 LIMITACIONES

Con el propósito de delimitar el área de estudio y garantizar la viabilidad del protocolo, se establecen las siguientes restricciones del proyecto:

- **Entornos productivos reales:** La metodología y el prototipo de software desarrollado no serán implementados ni testeados en infraestructuras analíticas en producción ni en redes vivas de ninguna empresa u organización activa en el país, debido a restricciones estrictas de confidencialidad y para mitigar riesgos de continuidad de negocio.
- **Solución comercial empaquetada:** La investigación no contempla el desarrollo de un producto de software comercial, un SIEM propietario o una plataforma empaquetada lista para el mercado.

- **Vectores de ataque excluidos:** El análisis analítico y el modelado predictivo se centrarán de forma exclusiva en campañas de actores de amenazas dirigido, excluyendo del alcance otras amenazas masivas o genéricas como ataques distribuidos de denegación de servicio (DDoS) a nivel de infraestructura de red o campañas masivas de spam no focalizado.

CAPÍTULO II. MARCO TEÓRICO

2.1 ANÁLISIS DE LA SITUACIÓN ACTUAL.

La protección de las infraestructuras críticas en Honduras —que abarcan sectores vitales como energía, telecomunicaciones, salud y el sistema financiero— se encuentra en una encrucijada operativa crítica. La gestión de ciberseguridad de los entornos locales opera predominantemente bajo esquemas tradicionales de naturaleza reactiva, lo que limita su capacidad para anticipar intrusiones complejas ejercidas por actores de amenaza a través de las diferentes Tácticas, Técnicas y Procedimientos (TTPs) que estos implementan. De acuerdo con las evaluaciones macro sobre la madurez de la ciberseguridad en América Latina, las capacidades de defensa e intercambio de inteligencia táctica muestran brechas estructurales profundas debido a restricciones de presupuesto y a la escasez de analistas especializados (Pavón et al., 2022)

Esta situación se ve agravada por la evolución tecnológica y la gestión de empresas en el entorno nacional, lo cual ha atraído la presencia de actores hostiles avanzados cuyas campañas dirigidas demuestran que las defensas estáticas perimetrales ya no son capaces de contener movimientos laterales complejos. Como demuestran empíricamente (Georgiadou et al., 2021), la proliferación de eventos anómalos benignos no correlacionados satura las capacidades analíticas de los equipos de respuesta (IT/OT), induciendo a una severa fatiga de alertas que dilata los tiempos de mitigación y vulnera la disponibilidad de los servicios esenciales.

Ante la falta de un marco soberano de priorización, las organizaciones locales importan flujos genéricos de Inteligencia de Amenazas (CTI) comerciales que saturan las consolas de monitoreo con Indicadores de Compromiso (IoCs) desconectados del contexto nacional (Suarez-Roman et al., 2026). El resultado es un Centro de Operaciones de Seguridad (SOC) con casos de uso no acordes con una gestión analítica de las TTPs u operación del actor, generando un procesamiento ineficiente y una capacidad sesgada de entender y reaccionar ante la presencia de un

incidente de ciberdefensa en el entorno real.

2.2 CONCEPTUALIZACIÓN

Para establecer el soporte semántico e interpretativo de esta investigación, la construcción del marco conceptual aborda la evolución dinámica y el consenso actual de los constructos centrales, superando la estructura de un glosario pasivo de términos.

El concepto de Inteligencia de Amenazas Cibernéticas (CTI) Táctica ha evolucionado significativamente desde la recolección estática y reactiva de firmas atómicas (como direcciones IP o hashes de malware) hacia el modelado conductual abstracto del adversario. Bajo la perspectiva actual de (Villalón Huerta, 2023) y la revisión sistemática, el consenso de la comunidad científica dictamina que la ciberinteligencia táctica debe fundamentarse en la categorización de Tácticas, Técnicas y Procedimientos (TTPs) a través de marcos estructurados como MITRE ATT&CK®. Esta dimensión trasciende los indicadores atómicos tradicionales al concentrarse en capturar las pautas repetibles de comportamiento del atacante, permitiendo interceptar intrusiones avanzadas de forma proactiva con independencia de las herramientas de software mutables que use el adversario.

De igual forma, la Gobernanza de Datos de Auditoría ha transitado desde un enfoque archivístico de cumplimiento normativo pasivo hacia un control de calidad técnico preventivo dentro de la arquitectura de seguridad. En la actualidad, se define como el conjunto coordinado de políticas, validaciones sintácticas y pipelines algorítmicos aplicados directamente en el origen del dato. Su propósito es certificar la calidad, integridad estructural, completitud y el no repudio de los registros de actividad (logs) emitidos por dispositivos heterogéneos antes de su ingesta en los motores analíticos, neutralizando el ruido sintáctico que propicia desviaciones en el diagnóstico defensivo.

Por su parte, el fenómeno denominado Fatiga de Alertas del SOC se conceptualiza científicamente como la degradación de la capacidad de atención y respuesta cognitiva del analista debido a la sobreexposición a volúmenes masivos de alertas de seguridad redundantes o falsos positivos. Su origen radica en el diseño de reglas de correlación y casos de uso basados en umbrales estáticos y firmas aisladas, omitiendo el contexto de un vector de ataque

multidimensional, la secuencia conductual de una TTP y el perfil específico del actor que dirige la campaña de intrusión.

Finalmente, las variables de Entorno Geopolítico, Vectores de Ataque y el Nivel de Madurez de Ciberseguridad Local constituyen constructos interdependientes que determinan la probabilidad real de que un sector estratégico sea seleccionado como objetivo prioritario por un adversario. La literatura científica moderna establece que el riesgo no es una probabilidad abstracta global, sino un cálculo condicionado por dinámicas socioeconómicas territoriales, motivaciones de extorsión financiera regionales y el grado de capacidad regulatoria y técnica que posee un país específico para identificar, proteger, detectar y recuperar sus activos esenciales frente a incidentes a gran escala.

2.3 TEORÍAS DE SUSTENTO

2.3.1 BASES TEORICAS

El núcleo metodológico y la innovación profesionalizante de la presente propuesta unifican e interconectan marcos teóricos complementarios estudiados a lo largo de la maestría, aplicándolos articuladamente a una realidad concreta del entorno nacional: la optimización y ciberdefensa de las infraestructuras críticas y sectores estratégicos de Honduras.

En primera instancia, se adopta el Modelo de Riesgo Cuantitativo Orientado al Adversario de (Ahmed et al., 2022). Esta teoría matemática descarta las evaluaciones cualitativas subjetivas convencionales y las sustituye por ecuaciones probabilísticas ligadas a Grafos de Ataque dinámicos. El modelo establece que la probabilidad de ocurrencia de una amenaza (LO, Likelihood of Occurrence) es una función directa de las capacidades del atacante parametrizadas geográficamente mediante el Interés de la Industria (II) y el Interés de la Región (RI), adicionando un factor de calibración determinista para entornos reales corporativos expresado en la ecuación:

$$LO = II + RI + 0.2$$

Este cálculo se intercepta analíticamente con la trayectoria táctica del adversario para predecir el tiempo de compromiso del activo. Esta investigación aplica formalmente dicha matemática ejecutando su calibración adaptativa para Honduras, asignando pesos específicos a II y RI según el perfil de riesgo de los sectores nacionales de la Banca, Energía y Gobierno.

La segunda teoría de soporte es el marco arquitectónico de Arquitectura Zero Trust (ZTA), normado internacionalmente por la publicación especial NIST SP 800-207 (Rose et al., 2020). Este enfoque defensivo elimina el principio de confianza implícita basado en la ubicación lógica o perímetro de red, exigiendo una verificación continua, dinámica y explícita de cada sujeto, dispositivo y flujo de datos dentro de la infraestructura. Su operativización mandata que los Motores de Políticas (Policy Engine) responsables de autorizar los accesos y alertamientos analíticos se alimenten de una telemetría ambiental íntegra, continua y de alta fidelidad.

Finalmente, se incorpora el Marco de Riesgo Técnico-Cultural (Georgiadou et al., 2021). Este enfoque postula que la vulnerabilidad de las redes de infraestructuras críticas, especialmente en entornos donde convergen tecnologías de la información (TI) y tecnologías de operación (OT), está fuertemente ligada a variables organizacionales y operativas. Explica cómo las deficiencias analíticas y la falta de correlación contextual facilitan que los atacantes ejecuten técnicas de evasión avanzada como Controls Override (manipulación o borrado de bitácoras) para saltar lateralmente hacia sistemas industriales y SCADA aprovechando la distracción analítica.

Articulación Coherente de las Metodologías: La pertinencia de esta unión reside en la codependencia técnica de los marcos. El algoritmo predictivo de CTI de Ahmed et al. (2022) colapsará y emitirá falsos positivos si procesa datos ruidosos, corruptos o alterados por técnicas de evasión, cumpliendo el axioma de ingeniería de 'Garbage In, Garbage Out'. Por lo tanto, la metodología de Gobernanza de Datos diseñada bajo los principios Zero Trust de la norma NIST SP 800-207 actúa como el pipeline de control y validación semántica preanalítica que limpia los logs en la fuente de origen antes de su transmisión. Al articular secuencialmente ambos enfoques, se dota a los SOC's hondureños de una telemetría pura, permitiendo que las ecuaciones calibradas de Ahmed calculen con precisión matemática cuál actor representa el riesgo más alto e inmediato, reduciendo drásticamente la fatiga de alertas y optimizando los recursos del país.

2.3.2 METODOLOGIAS DESARROLLADAS

En el estado del arte de la ciberdefensa se identifican tres enfoques metodológicos alternativos utilizados en procesos de investigación similares, cuyas limitaciones críticas justifican el desarrollo de esta propuesta unificada:

- **Modelado Estocástico Basado en CVSS:** Enfoque clásico centrado en la severidad intrínseca y estática de las vulnerabilidades informáticas. Su gran limitación metodológica es que asume un entorno defensivo pasivo, ignorando las capacidades dinámicas del adversario, el historial conductual de sus campañas y el contexto geográfico o sectorial específico de la organización evaluada.
- **Mapeo Automatizado mediante Procesamiento de Lenguaje Natural (NLP):** Metodologías de vanguardia emplean modelos de aprendizaje automático e inteligencia artificial para extraer TTPs a partir de reportes de CTI en texto libre crudo. A pesar de su innovación algorítmica, padecen el denominado Supuesto de Ingesta Ideal, pues su precisión analítica decae exponencialmente si las fuentes de telemetría y logs de auditoría originales del SOC de destino contienen ruido estructural, duplicidades sintácticas o incompatibilidades de formato.
- **Gráficos de Conocimiento Defensivo (MITRE D3FEND™):** Enfoques orientados a estructurar de manera semántica las contramedidas técnicas de ingeniería defensiva (como el engaño, el aislamiento o el análisis de linaje de procesos). Si bien organizan de manera excelente la matriz de respuestas frente a MITRE ATT&CK®, carecen de ecuaciones probabilísticas dinámicas para priorizar de forma predictiva qué contramedidas desplegar primero en entornos operativos con recursos financieros y humanos altamente restrictivos.

Este análisis crítico del estado del arte revela la Brecha de Investigación (Research Gap): la ausencia de un marco metodológico híbrido que unifique las ecuaciones predictivas de riesgo geopolítico (CTI táctica) con pipelines estrictos de gobernanza de datos para la normalización, validación semántica y limpieza de registros lógicos directamente en la fuente de origen dentro de los Centros de Operaciones de Seguridad de economías emergentes.

2.3.3 INSTRUMENTOS UTILIZADOS

La operativización de los modelos y metodologías analizados en la literatura científica previa

evidencia el empleo de instrumentos técnicos específicos que sirven como marcos de referencia instrumental para la presente investigación.

1. Matrices de Comportamiento Adversario MITRE ATT&CK®: Empleando de forma unificada las matrices conductuales de Enterprise e ICS (Sistemas de Control Industrial) como un instrumento taxonómico granular para mapear las tácticas del atacante en entornos híbridos y rastrear la progresión de movimientos laterales.
2. Algoritmos de Normalización en Tiempo Real de Gerhards (2016): Utilizando estructuras de clasificación basadas en Grafos Acíclicos Dirigidos (PDAG) en lugar de expresiones regulares tradicionales. Este instrumento de software es el que permite procesar masivamente mensajes de logs heterogéneos bajo condiciones de cargas operativas masivas sin introducir latencia o retrasos en el motor de ingesta del SIEM.
3. Instrumentos de Control Temporal y Enrutamiento: Mediante motores de enrutamiento avanzado (syslog-ng) e instrumentos de monitoreo temporal de eventos basados en la inyección de mensajes tipo heartbeat (latidos de estado temporales) validados en los principios de motores como VTEC de AMD o PROID. Estos instrumentos de software permiten aislar el ruido de los eventos benignos del sistema y alertar de forma automatizada sobre la interrupción u opacidad de los flujos de datos debida a técnicas de evasión del intruso.

2.4 MARCO LEGAL

El desarrollo y la futura implementación de la metodología propuesto interactúan directamente con un estricto ecosistema regulatorio y de cumplimiento sectorial (Compliance)

aplicable en la República de Honduras, obligando a las organizaciones a transicionar desde auditorías manuales reactivas hacia controles de ingeniería continuos.

2.4.1 Marco Regulatorio Nacional

Normas para la Gestión del Riesgo Tecnológico de la CNBS (Resolución GE No. 342/2018, Artículo 21): Emitida por la Comisión Nacional de Bancos y Seguros, esta normativa posee fuerza de ley y es de cumplimiento obligatorio para todas las instituciones del sistema financiero, asegurador y de pensiones que operan en Honduras. El Artículo 21 dictamina de forma mandatoria la creación, mantenimiento y custodia inalterable de Pistas de Auditoría (Logs) detalladas para registrar cualquier acceso, modificación o transacción lógica en las plataformas y servicios críticos del negocio. En el escenario analizado en esta investigación, la "fatiga de alertas" provocada por el ruido semántico de los registros degradados genera ceguera operativa, haciendo que el SOC pase por alto anomalías reales. Esto sitúa a las entidades en una posición de incumplimiento legal latente ante el ente regulador, exponiéndolas a severas sanciones punitivas y multas económicas. El insumo final de esta tesis —el pipeline de software unificado— automatiza y asegura la legibilidad de estas pistas de auditoría exigidas por el Artículo 21, al tiempo que calibra localmente el algoritmo de riesgo (Ahmed et al., 2022) mediante las variables regionales (RI e II) para proveer la proactividad analítica que la CNBS demanda.

2.4.2 Estándares Internacionales Vinculantes en el Entorno Nacional

- Estándar de Seguridad de Datos de la Industria de Tarjetas de Pago (*Official PCI Security Standards Council Site - Document*, s. f.): Este estándar internacional constituye una obligación jurídica en Honduras mediante vínculos contractuales comerciales que condicionan de forma mandatoria la operación de cualquier entidad que procese, almacene o transmita datos de tarjetas de crédito o débito. El Requisito 10 (Rastrear y supervisar todos los accesos a los recursos de red y a los datos de los titulares de tarjetas) obliga legalmente a los SOC's organizacionales a centralizar y revisar los logs de seguridad al menos una vez al día. La problemática identificada en este estudio demuestra que la dependencia de feeds globales redundantes expuestos en el Echo Chamber Effect (Suarez-Roman et al., 2026) satura las consolas analíticas con falsos positivos, haciendo humanamente imposible dicha revisión diaria. El incumplimiento de PCI-DSS faculta a las

marcas de tarjetas a revocar de inmediato la licencia de operación de la entidad bancaria, forzando al cese de sus transacciones en el país. El prototipo de software propuesto actúa como un motor de cumplimiento automatizado del Requisito 10, consolidando los flujos masivos de logs en subgrafos limpios de ataque (Peng & Zhang, s. f.) para interceptar intrusiones dirigidas en tiempo real.

- Norma Internacional ISO/IEC 27001:2022 (Controles A.8.10 y A.8.14): Si bien nace como un marco internacional, ISO 27001 se transforma en una exigencia legal de cumplimiento en el entorno hondureño mediante decretos de modernización institucional y pliegos de condiciones obligatorios para licitaciones tecnológicas del Estado y del sector corporativo masivo. El Control A.8.10 (Seguridad en los registros de auditoría) exige que las bitácoras lógicas estén estrictamente protegidas contra la modificación, eliminación o falsificación. Asimismo, el Control A.8.14 (Reducción de vulnerabilidades técnicas) demanda el monitoreo constante ante amenazas emergentes. La fatiga analítica actual impide que las fuentes de telemetría sean verificadas oportunamente en el SIEM, abriendo una brecha donde técnicas de evasión como Controls Override corrompen la evidencia. El pipeline de gobernanza desarrollado bajo los principios de verificación continua de la norma NIST SP 800-207 inspecciona sintácticamente cada log en el origen, proveyendo de manera automatizada la pista matemática inalterable que el auditor de ISO requiere para certificar la infraestructura nacional.

CAPÍTULO III. METODOLOGÍA

2.5 CONGRUENCIA METODOLÓGICA

En este capítulo se detalla la ruta operativa y procedimental seguida para llevar a la práctica los controles de ingeniería propuestos, justificando científicamente la selección de cada componente técnico. De acuerdo con las exigencias de la investigación aplicada en ciberseguridad, este estudio se desarrolla bajo un enfoque mixto (cuantitativo-cualitativo). La adopción de este enfoque responde a la necesidad de controlar los márgenes de error y maximizar el grado de confiabilidad de la telemetría procesada en el Centro de Operaciones de Seguridad (SOC). El componente cualitativo legitima el modelado taxonómico y conductual de los actores de amenaza mediante la identificación de sus Tácticas, Técnicas y Procedimientos (TTPs) en MITRE ATT&CK®. En contrapartida, el componente cuantitativo es indispensable para parametrizar de forma matemática el riesgo predictivo local mediante ecuaciones de probabilidad de ocurrencia (LO), así como para someter a pruebas estadísticas el rendimiento de las consolas analíticas (Tasa de Falsos Positivos y tiempos de respuesta) tras la aplicación de los algoritmos de gobernanza de logs.

2.5.1 MATRIZ METODOLÓGICA

Para garantizar la consistencia analítica interna de la investigación, se establece la alineación directa entre el título del proyecto, el desglose jerárquico de los objetivos y las variables operacionales involucradas:

Tabla 1: Matriz Metodológica de Alineación entre Título, Objetivos y Variables del Framework

Título de la investigación	Objetivos de investigación: General	Objetivos de investigación: Específicos	Variables
Metodología De Inteligencia De Amenazas (CTI) basada En Mitre Att&ck y Gobernanza De Datos para la	Desarrollar un framework unificado que integre un pipeline de gobernanza de logs en origen y un	O1: Calibrar los perfiles de amenazas locales para Honduras mediante la parametrización de feeds globales de	Variable Independiente (X_1): Mapeo Geopolítico en OpenCTI (Variables RI e II).

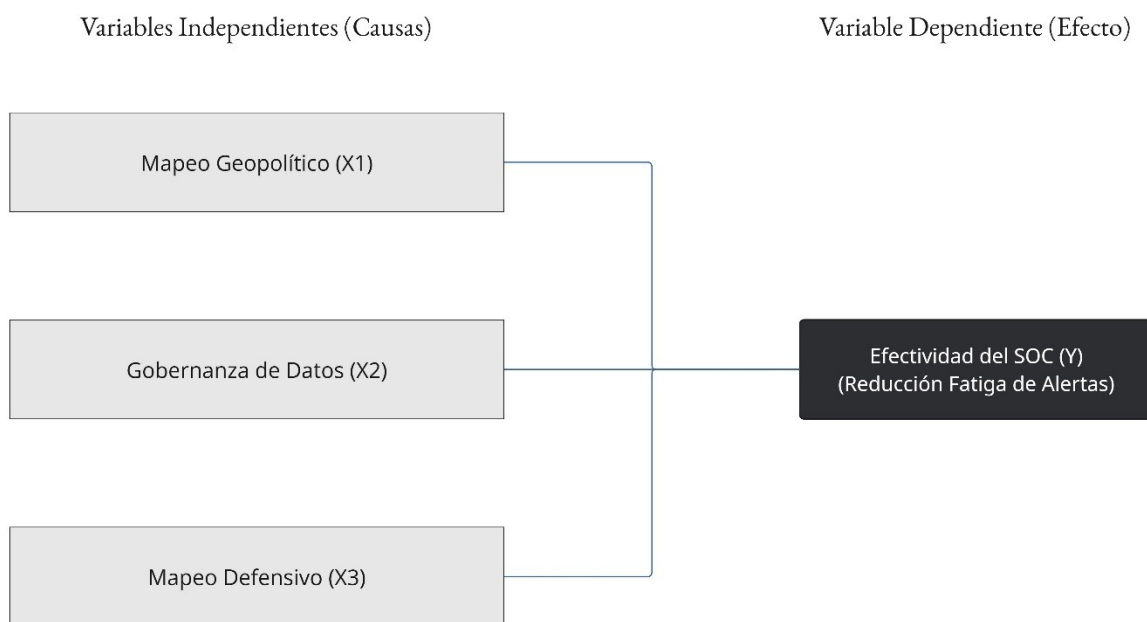
Priorización de Actores de Amenaza en Honduras.	modelo de inteligencia de amenazas adaptado al contexto nacional, para optimizar el rendimiento analítico y mitigar la fatiga de alertas en los SOCs de Honduras.	ciberinteligencia táctica. O2: Diseñar un pipeline automatizado de gobernanza de datos que normalice semánticamente los registros lógicos en la fuente de origen. O3: Evaluar el impacto del framework sobre la fatiga analítica mediante la asignación automatizada de contramedidas tácticas en el SOC.	Variable Independiente (X_2): Nivel de Gobernanza de Datos (Coeficiente de ruido estructural). Variable Independiente (X_3): Mapeo Defensivo en MITRE D3FEND™. Variable Independiente (Y): Efectividad operativa y reducción de la fatiga de alertas (TFP, MTDD, MTTR).
---	---	--	---

Nota. Matriz de consistencia interna y operativización metodológica de la investigación. *CTI* = Inteligencia de Amenazas Cibernéticas (Cyber Threat Intelligence); *SOC* = Centro de Operaciones de Seguridad; *RI* = Interés Regional; *II* = Interés de Industria; *TFP* = Tasa de Falsos Positivos; *MTDD* = Tiempo Medio de Detección; *MTTR* = Tiempo Medio de Respuesta. Elaboración propia.

2.5.2 ESQUEMA DE VARIABLES DE ESTUDIO

En este apartado se expresan las variables del sistema en términos de la relación de causalidad y el vínculo técnico que existe entre ellas. La lógica del framework determina que el comportamiento de la variable dependiente final está condicionado por la manipulación controlada de los tres componentes de ingeniería previos. El argumento causal se establece de la siguiente manera: El mapeo geopolítico de amenazas locales (X_1), coordinado con el nivel de gobernanza y normalización de datos lógicos en la fuente de origen (X_2), aunado con un despliegue de contramedidas tácticas basadas en MITRE D3FEND™ (X_3), determina el nivel de efectividad operativa y la reducción de la fatiga de alertas (Y) en los Centros de Operaciones de Seguridad (SOC) en Honduras. Para la representación visual de este vínculo multivariado en el documento final, se utiliza el siguiente diagrama sagital de relaciones lógicas:

Ilustración 1: Diagrama Sagital de Relación Causal entre las Variables Independientes y Dependiente del Framework



Nota. Estructura multivariada de causalidad del estudio donde X_1 representa el Mapeo Geopolítico, X_2 la Gobernanza de Datos y X_3 el Mapeo Defensivo, convergiendo en la variable de respuesta Y (Efectividad del SOC y reducción de la fatiga analítica). SOC = Centro de Operaciones de

Seguridad (Security Operations Center). Elaboración propia.

2.5.3 OPERACIONALIZACIÓN DE LAS VARIABLES

En este apartado se estructuran y desglosan las variables que componen la arquitectura causal del framework de ciberseguridad, con el objetivo de definir de manera unívoca sus alcances teóricos y los procedimientos experimentales necesarios para su medición cuantitativa. Para cada variable del sistema, se delimita su definición conceptual —sustentada en el consenso científico de las bases de conocimiento y estándares adoptados— y su definición operacional, la cual describe las ecuaciones algebraicas, métricas informáticas y metodologías de extracción automatizada que permiten capturar los valores reales dentro del laboratorio controlado. Asimismo, se identifican las dimensiones teóricas que articulan cada variable y los ítems o indicadores específicos sujetos a cuantificación estadística para el contraste de las hipótesis formuladas.

Tabla 2: Matriz de Operacionalización de Variables Independientes y Dependiente del Framework

Variable	Definición Conceptual	Definición Operacional	Dimensiones	Ítems/ Indicadores
Mapeo Geopolítico (X_1)	Dimensión analítica orientada a contextualizar la Inteligencia de Amenazas Cibernéticas (CTI) Táctica mediante la parametrización de la afinidad regional y	Cálculo matemático determinista de la Probabilidad de Ocurrencia (LO) mediante la agregación de pesos discretos asignados a la industria y la localización geográfica del objetivo, expresado por la ecuación de (Ahmed et al., 2022): $LO = II + R1 + 0.2$	Contexto Geográfico Nacional. Afinidad Sectorial Operativa.	Puntuación de afinidad regional para la República de Honduras (RI). Puntuación de afinidad sectorial para infraestructuras críticas hondureñas (II).

	sectorial de un adversario humano.			
Nivel de Gobernanza de Datos (X_2)	Pipeline de ingeniería de ciberseguridad diseñado bajo el principio de verificación continua de la Arquitectura Zero Trust (ZTA) para certificar la integridad semántica, normalización sintáctica y calidad de los registros lógicos en su origen.	Aplicación algorítmica de enrutamiento y parseo estructurado de eventos lógicos que purifica el flujo total de telemetría (D), aislando y minimizando el subconjunto de ruido computacional o registros degradados (D_r) mediante agentes recolectores <i>syslog-ng</i> , expresado como el residuo de entropía estructural: $D_r = D - D_p$	Normalización Estructural del Log. Calidad y Fidelidad de la Telemetría.	Volumen de Eventos por Segundo (EPS) normalizados de forma paralela. Porcentaje de registros lógicos con campos nulos o errores sintácticos en origen.
Mapeo Defensivo MITRE D3FEND™ (X_3)	Orquestación y despliegue de contramedidas técnicas de ingeniería defensiva basadas en un	Intercepción automática y traducción lógica de las alertas conductuales detectadas frente al catálogo de técnicas de protección del grafo oficial D3FEND v1.4, verificando el cambio de estado operacional del	Orquestación de Respuesta Táctica. Contramedidas de Ingeniería	Identificador del control defensivo ejecutado (e.g., D3-MFA Multi-Factor Authentication, D3-NI Network Isolation).

	grafo de conocimiento semántico relacional para neutralizar Tácticas, Técnicas y Procedimientos (TTPs) ofensivas específicas.	control de endurecimiento (<i>hardening</i>) o aislamiento dentro del entorno simulado.	Defensiva.	Tasa de éxito operacional del bloqueo ante la ejecución del exploit.
Efectividad Operativa del SOC (Y)	Capacidad analítica y cognitiva de optimización de un Centro de Operaciones de Seguridad (SOC) para mitigar la fatiga de alertas del personal reduciendo el ruido informático benigno y acelerando los tiempos de contención de	Evaluación cuantitativa multivariable del rendimiento de la consola SIEM en el laboratorio a través de tres métricas de tiempo y precisión: 1. Tasa de Falsos Positivos (TFP): $TFP = \frac{\sum Alertas Falsas}{\sum Alertas Totales} \times 100$ 5. Tiempo Medio de Detección (MTTD): $MTTD = \frac{\sum Tiempos de Detección}{\sum Alertas}$	Precisión de la Alerta Defensiva. Eficiencia Temporal Analítica.	Porcentaje de alarmas descartadas por irrelevancia (% TFP). Segundos transcurridos entre la ejecución de la TTP y el alertamiento en consola (MTTD). Segundos transcurridos desde la alerta hasta el despliegue del control de

	amenazas.	$\frac{\sum (t_{alerta} - t_{inyección})}{N}$		contención (MTTR).
		6. Tiempo Medio de Respuesta (MTTR): $MTTR = \frac{\sum (t_{contención} - t_{alerta})}{N}$		

Nota. Operacionalización de variables del diseño metodológico cuasiexperimental. *LO* = Probabilidad de Ocurrencia (Likelihood of Occurrence); *RI* = Interés Regional; *II* = Interés de Industria; *ZTA* = Arquitectura Zero Trust (Zero Trust Architecture); *EPS* = Eventos por Segundo; *TTP* = Tácticas, Técnicas y Procedimientos; *SOC* = Centro de Operaciones de Seguridad; *TFP* = Tasa de Falsos Positivos; *FP* = Falsos Positivos; *TP* = Verdaderos Positivos; *MTTD* = Tiempo Medio de Detección (Mean Time to Detect); *MTTR* = Tiempo Medio de Respuesta (Mean Time to Respond). Elaboración propia.

2.5.4 HIPÓTESIS

Debido a que el alcance de esta investigación aplicada es correlacional y explicativo, cuantifica la relación causal entre la gobernanza de datos de registro/priorización táctica y la eficiencia analítica del sistema de detección, lo que requiere la formulación y validación de hipótesis estadísticas. Estas están directamente correlacionadas con el Objetivo Específico 3 (OE3):

Hipótesis de Investigación (H_1): La implementación de un framework unificado que integra el mapeo geopolítico local en OpenCTI, el pipeline de gobernanza de datos en origen y las contramedidas de MITRE D3FEND™, reduce significativamente la Tasa de Falsos Positivos (TFP) y disminuye el Tiempo Medio de Detección (MTTD) en un Centro de Operaciones de Seguridad (SOC) simulado, en comparación con el esquema operativo tradicional.

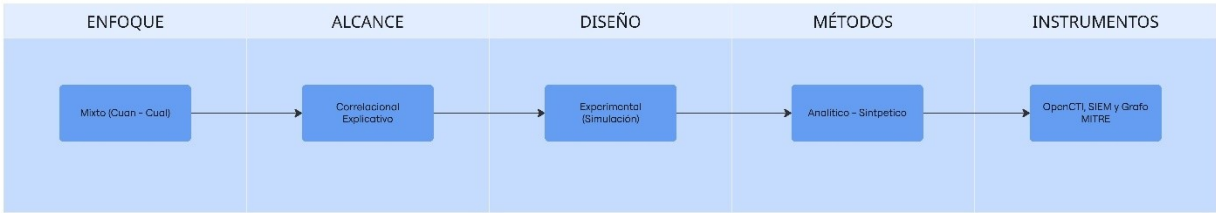
Hipótesis Nula (H_0): La implementación del framework unificado de ciberseguridad propuesto no

genera variaciones ni reducciones significativas en la Tasa de Falsos Positivos (TFP) ni en el Tiempo Medio de Detección (MTTD) dentro del entorno del SOC simulado.

2.6 ENFOQUE Y MÉTODOS

En este apartado se especifican de manera integrada los pilares metodológicos que guían el desarrollo de la investigación. El estudio adopta un enfoque mixto, coordinando técnicas cualitativas de modelado con análisis cuantitativos de telemetría. El alcance es correlacional-explicativo, orientado a determinar las causas del colapso analítico (fatiga de alertas) y medir el impacto predictivo de la solución. El diseño es experimental basado en simulación, utilizando el método analítico-sintético para el procesamiento de los datos recolectados mediante herramientas especializadas de ciberseguridad.

Ilustración 2: Articulación Metodológica de la Investigación: Enfoque, Alcance, Diseño, Métodos e Instrumentos



Nota. Representación secuencial de la estructura metodológica implementada para la validación del framework. SIEM = Gestión de Información y Eventos de Seguridad (Security Information and Event Management); Cuan = Cuantitativo; Cual = Cualitativo. Elaboración propia.

2.7 DISEÑO DE LA INVESTIGACIÓN

2.7.1 POBLACIÓN

La población o universo objeto de estudio se define de forma rigurosa como la totalidad de los eventos lógicos, flujos de tráfico de red y mensajes de auditoría computacional generados en formatos heterogéneos (Syslog, JSON, Windows Event Logs) por los servidores, firewalls y controladores lógicos programables (PLC) durante una campaña activa de intrusión dentro de una

infraestructura crítica híbrida (IT/OT). Para efectos del diseño experimental del laboratorio controlado, el universo total estimado de eventos lógicos y registros de auditoría inyectados durante el ciclo completo de simulación es de $N = 10,000$ mensajes computacionales.

2.7.2 MUESTRA

La muestra representa la porción de la población seleccionada para el análisis de rendimiento y la comprobación estadística de las hipótesis. Al tratarse de variables categóricas (donde cada alerta emitida por el SIEM se clasifica binariamente como *Falso Positivo* o *Alerta Verídica de Ataque*), se aplica la fórmula de tamaño muestral para poblaciones finitas con variables categóricas dictada por el manual de la universidad:

$$norte = \frac{PAG \times Q \times CON^2 \times norte}{PAG \times Q \times CON^2 + y^2 \times norte}$$

Para garantizar el éxito de los resultados y la representatividad del universo, se parametrizan los valores del cálculo basándose en la literatura científica previa del estado del arte:

- norte = 10,000 (Universo total de eventos generados en el escenario de ataque).
- PAG = 0,10 (Probabilidad estimada de que un evento constituya una alerta verídica de ataque; equivalente al 10%).
- Q = 0,90 (Probabilidad de que el evento represente ruido semántico o falsos positivos antes del framework; $1 - PAG = 90\%$).
- CON = 1,96 (Nivel de confianza fijado en el 95%)
- y = 0,05 (Margen de error estándar aceptado del 5%)

Reemplazando los valores en la ecuación metodológica institucional, el desarrollo matemático es el siguiente:

$$norte = \frac{0,10 \times 0,90 \times (1,96)^2 \times 10,000}{0,10 \times 0,90 \times (1,96)^2 + (0,05)^2 \times 10,000}$$

$$norte = \frac{0,09 \times 3.8416 \times 10,000}{0,09 \times 3.8416 + 0,0025 \times 10,000}$$

$$norte = \frac{3,457,44}{0,345744 + 25}$$

$$norte = \frac{3,457,44}{25.345744}$$

$$norte = 136,41 \approx 137$$

Redondeando al siguiente valor entero superior para garantizar la robustez estadística exigida, el tamaño mínimo de la muestra aleatoria de alertas que los investigadores extraerán de forma automatizada de la consola SIEM para auditar y validar estadísticamente las métricas de efectividad (TFP, MTDD) es de 137 eventos lógicos, asegurando con ello el cumplimiento del grado de confiabilidad exigido por la facultad de postgrado.

2.7.3 TÉCNICAS DE MUESTREO

En las técnicas de muestreo se selecciona una estrategia de muestreo no probabilístico por conveniencia u objetivo técnico. El desarrollo de esta investigación aplicada exige la detonación controlada de exploits y scripts de ataque automatizados basados en matrices ofensivas avanzadas, así como la manipulación de flujos de bitácoras. Ejecutar este procedimiento de ingeniería dentro de una infraestructura de red en producción real de una entidad bancaria o gubernamental activa en el entorno nacional es inviable y crítico, debido a las restricciones legales de confidencialidad de datos (Compliance) y al riesgo inherente de comprometer la disponibilidad de servicios esenciales para el país.

Por lo tanto, los investigadores recurren a elementos disponibles y accesibles mediante el despliegue de un laboratorio virtualizado y aislado (sandbox). El muestreo es dirigido de forma técnica para extraer de la consola centralizadora únicamente aquellos eventos lógicos y marcas de tiempo (timestamps) que correspondan de manera exacta a las fases del protocolo experimental,

aislando el ruido ambiental rutinario de los sistemas operativos. Se reconoce formalmente que el muestreo por conveniencia no garantiza una representatividad estadística probabilística global frente a todo el espectro de amenazas asimétricas; no obstante, bajo el paradigma de la metodología Design Science Research (DSR), esta técnica es plenamente útil y válida, ya que provee el subconjunto de datos puros (norte = 137 logs) necesarios para someter a prueba la lógica algorítmica del prototipo middleware, calcular las ecuaciones de probabilidad de ocurrencia local y validar cuantitativamente la reducción de falsos positivos en las consolas de monitoreo.

2.8 TÉCNICAS, INSTRUMENTOS Y PROCEDIMIENTOS APLICADOS

Con el objetivo de operacionalizar el framework y asegurar un control estricto sobre el margen de error y la confiabilidad de los datos procesados, se estructuran los siguientes componentes procedimentales:

Técnicas:

- *Simulación Experimental*: Técnica principal empleada para recrear y emular de forma controlada la topología de red híbrida, la inyección asíncrona de logs y la ejecución secuencial de las campañas de ataque sin alterar plataformas de producción.
- *Revisión Sistemática de Literatura*: Aplicada para la extracción sintáctica, ingesta y normalización de las bases de conocimiento relacionales globales organizadas por MITRE Corporation.
- *Análisis Normativo y de Cumplimiento (Compliance)*: Técnica utilizada para validar el grado de alineación técnica del artefacto frente a las regulaciones financieras locales e internacionales obligatorias en el territorio nacional.

Instrumentos elaborados:

- *Protocolo Experimental de Inyección Automática de TTPs*: Guía algorítmica y scripts automatizados encargados de detonar de manera idéntica y reproducible las técnicas ofensivas de los actores de amenaza seleccionados.

- *Plantilla Automatizada de Extracción de Timestamps y Métricas:* Scripts en lenguaje Python desarrollados específicamente para interactuar con la base de datos del SIEM y extraer las marcas de tiempo requeridas para el cálculo matemático de la Tasa de Falsos Positivos (% TFP), el MTTD y el MTTR.
- *Ficha de Evaluación y Calibración Geopolítica:* Instrumento de ponderación lógica estructurado para inyectar los pesos discretos de las variables de Industria de Interés (\$IIS) y Región de Interés (RI) en el motor de OpenCTI.

Procedimientos:

- *Paso 1. Configuración de la Infraestructura:* Despliegue de los entornos virtuales del laboratorio, inicialización de la plataforma TIP OpenCTI y configuración de los agentes de enrutamiento *syslog-ng* en los servidores emisores bajo políticas estrictas Zero Trust (NIST SP 800-207).
- *Paso 2. Simulación de Línea Base (Baseline):* Detonación de la campaña de ataques controlados sobre el laboratorio operando de forma convencional (logs en bruto y feeds globales con efecto de cámara de eco), recolectando las métricas iniciales de saturación y tiempos en el SIEM.
- *Paso 3. Activación del Framework Unificado:* Inicialización del pipeline de gobernanza de datos lógicos en origen y activación de las ecuaciones matemáticas calibradas de probabilidad de ocurrencia para Honduras.
- *Paso 4. Simulación de Benchmarking:* Ejecución de la misma campaña de ataques bajo las mismas constantes de control, forzando la interceptación analítica y la asignación automatizada de las contramedidas tácticas indexadas en el Grafo de MITRE D3FEND™.
- *Paso 5. Procesamiento Estadístico:* Extracción de la muestra aleatoria de 137 eventos mediante la plantilla automatizada y contraste de las hipótesis formuladas en el software estadístico para determinar el nivel de optimización operativa del SOC.

2.9 FUENTES DE INFORMACIÓN

2.9.1 FUENTES PRIMARIAS

Las fuentes primarias de esta investigación aplicada de ingeniería están constituidas de forma exclusiva por la telemetría digital cruda y los registros de auditoría computacional capturados directamente por los investigadores dentro del entorno de laboratorio controlado durante los ciclos de simulación. Estas fuentes primarias incluyen las marcas de tiempo lógicas (*timestamps*) originales de inyección, alertamiento y bloqueo de procesos extraídas de las bitácoras del SIEM, las tablas de eventos por segundo (EPS) normalizadas paralelas generadas por el pipeline de gobernanza de datos de auditoría, y los registros estructurados en formato JSON y esquemas STIX 2.1 resultantes de la depuración del ruido analítico dentro del servidor OpenCTI corporativo.

2.9.2 FUENTES SECUNDARIAS

Las fuentes secundarias de información proveen el sustento taxonómico, las bases matemáticas de riesgo y el marco normativo de cumplimiento obligatorio en el territorio hondureño que ampara la validez del artefacto tecnológico. Se detallan las fuentes utilizadas: las bases de conocimiento técnico, matrices relacionales y ontologías semánticas oficiales de MITRE Corporation (MITRE ATT&CK® Enterprise/ICS y MITRE D3FEND™ v1.4), el estándar de arquitectura y seguridad de la publicación especial NIST SP 800-207 para la validación continua de flujos lógicos, los modelos de riesgo probabilístico dinámico impulsados por el adversario documentados en la literatura científica internacional (Ahmed et al., 2022), y los reportes, circulares y marcos regulatorios estatales vigentes emitidos por la Comisión Nacional de Bancos y Seguros de Honduras (Resolución GE No. 342/2018, Artículo 21), complementados con las normativas contractuales internacionales del Requisito 10 de PCI-DSS v4.0 y los Controles A.8.10 y A.8.14 de la norma ISO/IEC 27001:2022 indexados formalmente en el gestor bibliográfico Zotero.

2.10 PIPELINE METODOLÓGICO Y DISEÑO DE SU ARQUITECTURA

El flujo sistémico de la investigación sigue una arquitectura secuencial en seis fases interconectadas, modelando el recorrido completo desde el origen de la inteligencia cruda hasta el despliegue de la respuesta táctica en el SOC:

Ilustración 3: Pipeline Metodológico y Arquitectura Secuencial de Seis Fases de la Investigación



Nota. Diagrama de bloques que describe el flujo metodológico y experimental del estudio, estructurado secuencialmente en seis fases: definición del problema, recolección de fuentes de datos, parametrización de instrumentos, procesamiento y decodificación de eventos, evaluación experimental y generación de resultados analíticos. SOC = Centro de Operaciones de Seguridad (Security Operations Center). Elaboración propia.

- **Problema:** Presencia de fatiga de alertas por falsos positivos debido a logs ruidosos y a la falta de un mapeo de casos de uso ajustado a actores de amenaza locales en Honduras.
- **Datos:** Ingesta en el pipeline de diferentes flujos de telemetría e indicadores de ciberinteligencia global desestructurada.
- **Instrumentos:** Despliegue de la plataforma OpenCTI como orquestador de inteligencia y del laboratorio SIEM SOC Simulado como entorno de detección controlado.
- **Procesamiento:** OpenCTI normaliza la amenaza y calcula la Probabilidad de Ocurrencia (LO), mientras el pipeline de gobernanza depura el ruido estructural de los logs antes de enviarlos a las reglas de correlación del SIEM.
- **Evaluación:** Inyección de la campaña de actores de amenaza conforme sus TTPs a través de los eventos simulados para activar los motores de correlación del SIEM.
- **Resultados y Respuesta:** Al detectarse el ataque predictivo, la metodología asigna de

forma automatizada la contramedida correspondiente del Grafo D3FEND (e.g., aislamiento de red o desalojo de procesos), calculando el impacto en el MTTR y la TFP finales.

2.11 ESTRATEGIA DE EVALUACIÓN

La comprobación metodológica y validación empírica del artefacto de software se realizan mediante una estrategia de Benchmarking comparativo de dos escenarios:

- **Baseline (Línea base):** Operación del SIEM simulado bajo el esquema tradicional defensivo, ingiriendo logs en bruto sin limpiar y consumiendo feeds comerciales globales afectados por la cámara de eco (Suarez-Roman et al., 2026) y estrategias de respuesta ad-hoc no estandarizadas, midiendo la TFP y el MTDD resultantes ante la campaña de ataque.
- **Benchmarking (Escenario Propuesto):** Operación de la misma topología integrando el framework desarrollado: OpenCTI para la priorización con la fórmula de Ahmed calibrada para Honduras, normalización de telemetría en la fuente, y el despliegue de respuestas estandarizadas mapeadas con MITRE D3FEND.
- **Métricas de Evaluación:** Comparación numérica de la reducción porcentual de la Tasa de Falsos Positivos (TFP) y la aceleración temporal del Tiempo Medio de Detección (MTDD) y Respuesta (MTTR).
- **Resultados Esperados:** Demostrar estadísticamente que vincular ATT&CK con D3FEND bajo una telemetría purificada reduce drásticamente el ruido analítico, eliminando la fatiga de alertas y permitiendo contener las amenazas de forma procedimental y veloz.

2.12 AMENAZAS A LA VALIDEZ

- **Validez Interna:** Riesgo de que en el entorno controlado del laboratorio las acciones automatizadas dictadas por MITRE D3FEND operen de manera idealizada frente a las TTPs emuladas. Se mitiga introduciendo retardos de tráfico de red aleatorios y la inyección de ruido de fondo operacional real para simular las fricciones operativas de un SOC.

- **Validez Externa:** Limitación de que las métricas probabilísticas calculadas (II y RI) estén estrictamente ajustadas a los perfiles de amenazas detectados en Honduras. Extrapolar el modelo de respuesta D3FEND a incidentes complejos de amenaza interna no estructurada en otras regiones geográficas requeriría una recalibración previa de las constantes del algoritmo.
- **Sesgos de Datos (Construcción):** Las fuentes globales de CTI presentan un marcado sesgo de observación geográfico hacia entornos comerciales hiperindustrializados (Suarez-Roman et al., 2026). Esto se mitiga triangulando y filtrando las ingestas con reportes orientados a cibercriminalidad en Latinoamérica, asegurando que el perfil del atacante ingestando a OpenCTI sea realista para Honduras.

2.13 ÉTICA, PRIVACIDAD Y GOBERNANZA DE DATOS

- **Uso de datos personales o sensibles:** Dado que la investigación se ejecuta exclusivamente dentro de un entorno de simulación experimental de laboratorio y utiliza datos sintéticos generados, se trabaja con datos conocidos en la industria de la seguridad, garantizando que no se recolecta, almacena ni procesa ningún dato de carácter personal, sensible o real de usuarios de ninguna institución del país.
- **Almacenamiento y Protección de Datos:** Todo el proceso de generación de eventos asíncronos y su correlación algorítmica se ejecuta de forma aislada dentro de las redes privadas y máquinas virtuales sandbox de las que consiste el laboratorio SOC simulado.
- **Riesgos Éticos y Estrategia de Mitigación:** Al simular tácticas avanzadas ligadas a actores de amenaza, el material de estudio no tiene un riesgo de impacto hostil externo. Las herramientas que se usarán serán controladas en un sandbox de desarrollo privado de la investigación, y los artefactos resultantes se almacenarán de forma segura y cifrada en el repositorio de GitHub para fortalecer el marco de gestión de riesgos tecnológicos académico.
- **Uso de Herramientas Tecnológicas:** La arquitectura dependerá de software de código abierto y licenciamiento académico utilizándose estrictamente con propósitos del

desarrollo de la investigación, cumpliendo con las pautas preventivas del marco de gestión de riesgos tecnológicos.

DECLARACIÓN DEL USO DE INTELIGENCIA ARTIFICIAL

- **Herramienta utilizada:** Gemini (Google).
- **Propósito de uso:** Organización de las secciones del diseño metodológico, refinamiento de la redacción científica técnica del capítulo y desarrollo analítico de la operacionalización de variables según el formato de documento base institucional.
- **Prompts principales utilizados:** *"Ayúdame a redactar una sección de justificación formal para mi tesis de ciberseguridad. El tema es la fatiga de alertas en el SOC. Necesito definir el sistema matemáticamente: el flujo total de logs es D , que se divide en datos puros D_p y ruido D_r . Quiero plantear un Teorema I de Optimización analítica donde si el ruido D_r tiende a cero en origen y calibramos la fórmula de Ahmed para Honduras, la Tasa de Falsos Positivos baja. Redáctalo con lenguaje académico basado en la norma NIST SP 800-207."*

"Tengo tres marcos teóricos para el Capítulo II y necesito unirlos en una redacción fluida sin que parezca un glosario de términos: 1) El modelo de riesgo de Ahmed (2022) con su fórmula $LO = II + RI + 0.2$, 2) La verificación continua de Zero Trust de la norma NIST SP 800-207, y 3) El enfoque de Georgiadou (2021) sobre fatiga de alertas y Controls Override. Explica cómo la gobernanza de logs en origen limpia los datos para que las ecuaciones de Ahmed funcionen bien sin meter datos basura."

"Necesito analizar el marco legal de Honduras aplicado a la ciberseguridad para mi tesis. Específicamente, cómo la fatiga de alertas afecta el cumplimiento del Artículo 21 de la Resolución GE No. 342/2018 de la CNBS (pistas de auditoría en la banca). Agrega también el Requisito 10 de PCI-DSS v4.0 y los controles A.8.10 de ISO 27001:2022 sobre protección y monitoreo de registros de auditoría."

"Ayúdame a estructurar la tabla de operacionalización de variables para mi Capítulo III. Mi diseño usa y elegimos Design Science Research (DSR) y simulación. Las variables independientes son Mapeo Geopolítico, Gobernanza de Datos y MITRE D3FEND. La

variable dependiente es la Efectividad Operativa del SOC. Incluye las fórmulas explícitas para calcular la Tasa de Falsos Positivos (TFP), MTTD y MTTR."

"Ayúdame a resolver la fórmula de tamaño de muestra para poblaciones finitas según el manual de la universidad. Mis datos son: universo total $N = 10,000$ logs generados en la simulación, probabilidad de alertas verídicas $P = 0.10$, ruido esperado $Q = 0.90$, confianza $Z = 1.96$ (95%) y margen de error $e = 0.05$ (5%). Haz el desglose matemático paso a paso para ponerlo en el Word."

"Redacta el procedimiento de laboratorio (sandbox) para evaluar mi framework. Necesito separar la metodología en fases continuas desde el problema hasta los resultados, explicar la estrategia de Benchmarking comparativo contra una línea base tradicional, y analizar las amenazas a la validez (interna, externa, sesgo geográfico de los feeds de CTI comerciales) y la parte ética de usar datos simulados."

- **Verificación y Edición:** Los autores (Eder y Suyapa) revisaron de forma crítica la prosa generada, completaron los cuadros relacionales de la matriz metodológica y auditaron la consistencia de las ecuaciones de las variables analíticas (TFP, MTTD, MTTR) frente a los parámetros reales definidos para la simulación del entorno de laboratorio antes de la consolidación final del entregable en formato PDF.

CAPÍTULO IV. RESULTADOS Y ANÁLISIS

En este capítulo se describe, ilustra y analiza la información recolectada durante la fase empírica y experimental de la investigación, estructurada en función de los objetivos específicos y las variables formuladas en el marco metodológico. La presentación de los resultados sigue una secuencia lógica y multivariada que articula la gobernanza preanalítica de registros en origen, el modelado de ciberinteligencia táctica contextualizada para Honduras en OpenCTI y la asistencia defensiva basada en la correlación del SIEM y el estándar MITRE D3FEND™. Cada sección analítica se fundamenta rigurosamente en tres niveles interpretativos: la identificación del hallazgo y su impacto en el proyecto, la determinación de la tendencia observada y la formulación de

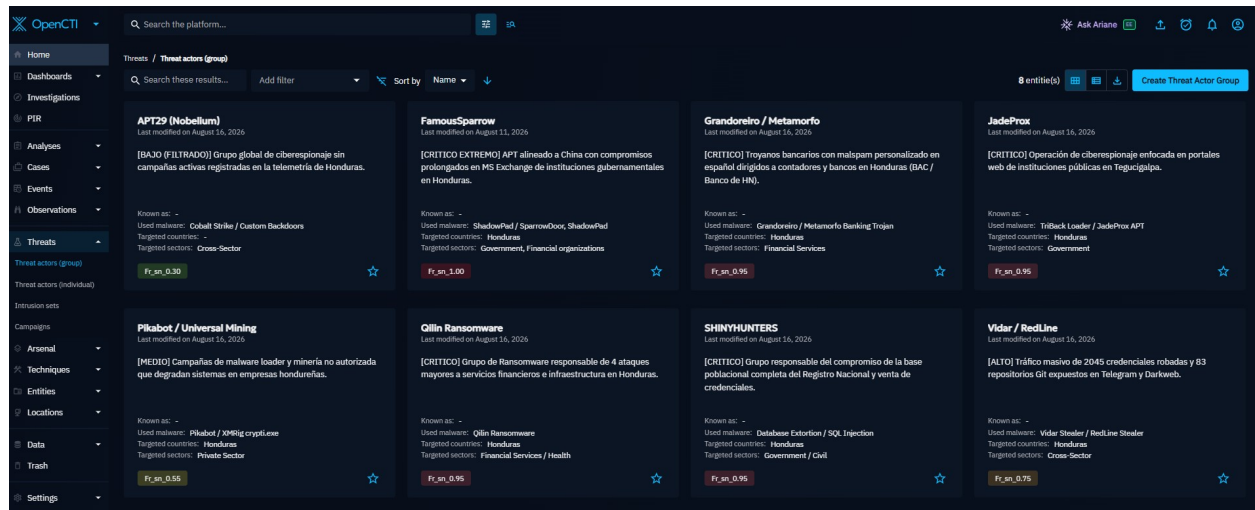
conclusiones con soporte estadístico y cualitativo.

2.14 INFORME DE PROCESO DE RECOLECCIÓN DE DATOS

La fase empírica de recolección y procesamiento de datos se ejecutó dentro de un entorno virtualizado y controlado (Sandbox sobre contenedores Docker y máquinas virtuales), diseñado para aislar los experimentos de infraestructuras en producción y garantizar la reproducibilidad científica del protocolo. El proceso de recolección se dividió en dos flujos metodológicos complementarios:

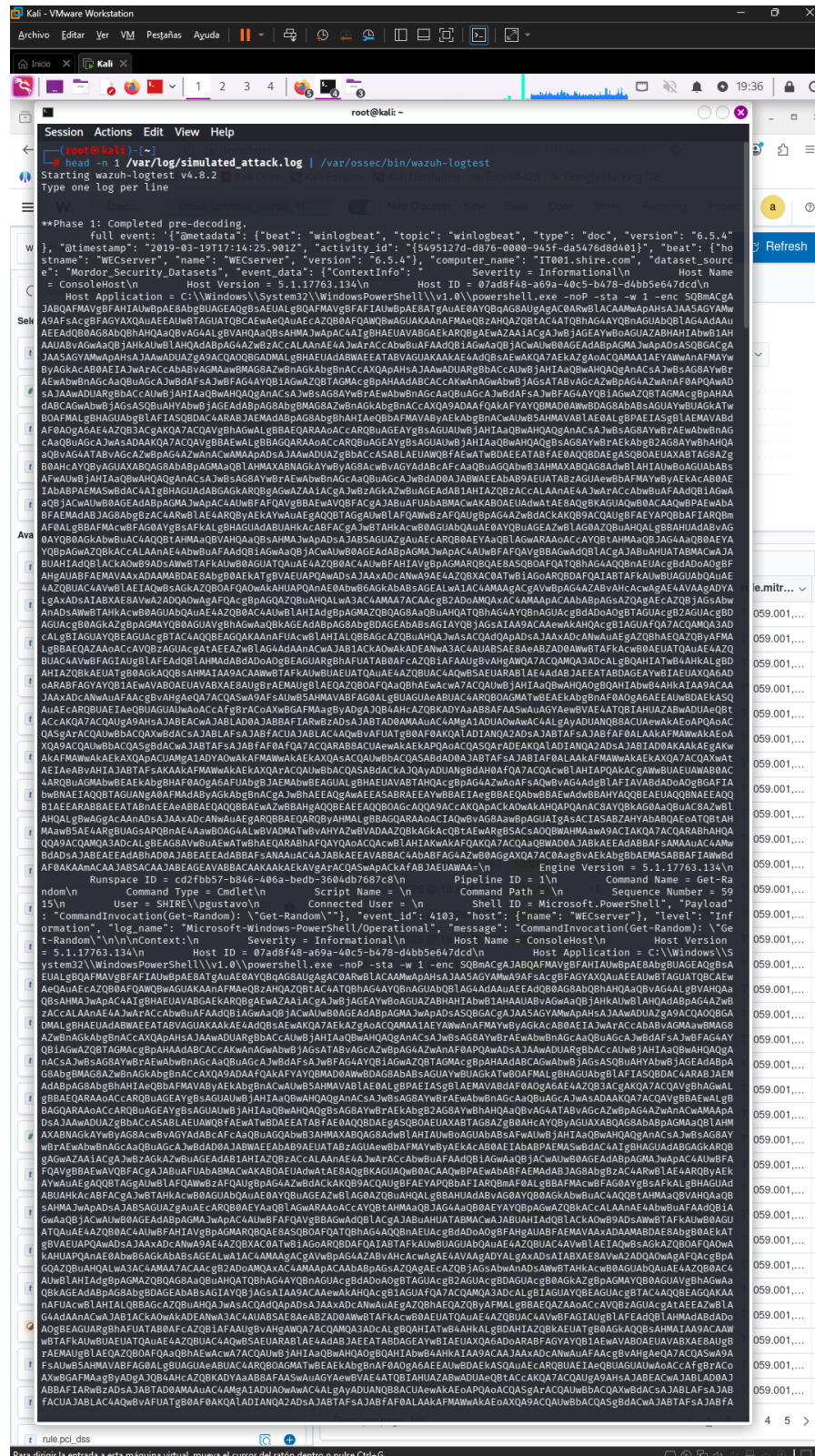
- **Extracción y Procesamiento de Ciberinteligencia (Capa Cualitativa/Táctica):** Se recopiló inteligencia de amenazas a partir de reportes especializados facilitados por Group-IB Threat Intelligence, complementados con registros del catálogo de vulnerabilidades explotadas (CISA KEV) y avisos de seguridad de FBI InfraGard. Estos datos no estructurados fueron normalizados bajo el estándar internacional STIX 2.1 e ingestados en la plataforma OpenCTI mediante conectores automatizados (*CSV Mappers* y *Connectors*). Se obtuvo una tasa de completitud del 100% en la estructuración de ocho actores de amenaza persistente avanzada (APT) y campañas dirigidas, asociando sus vectores de ataque (patrones de MITRE ATT&CK®), familias de malware y los sectores esenciales afectados en Honduras.
- **Captura de Telemetría y Registros Lógicos (Capa Cuantitativa/Experimental):** Para evaluar el comportamiento del pipeline de gobernanza de datos y el motor de correlación en el SIEM ante eventos de seguridad, se procesó un universo experimental de $N=1,186$ trazas lógicas reales e inyecciones sintéticas provenientes de repositorios de ciberseguridad (*Mordor Project*, *EVTX-ATTACK-SAMPLES* y *Splunk Attack Data*). Aplicando la fórmula de muestreo probabilístico para poblaciones finitas calculada en el marco metodológico, se extrajo y auditó una muestra representativa de $n=137$ registros lógicos críticos (con un nivel de confianza del 95% y un margen de error muestral del 5%). Estos registros fueron sometidos a verificación y decodificación sintáctica en el agente recolector antes de su indexación en la consola del SIEM.

Ilustración 4: Panel Consolidado de Actores de Amenaza y Nivel de Priorización Regional en OpenCTI



Nota. Consola central de OpenCTI que evidencia la parametrización de las ocho entidades de amenaza analizadas, su clasificación operativa (FR_SN_CRITICAL, FR_SN_HIGH, FR_SN_MEDIUM, FR_SN_LOW) y su focalización sectorial en Honduras. Elaboración propia a partir de OpenCTI.

Ilustración 5: Pipeline de Ingesta, Decodificación JSON y Validación de Reglas Jerárquicas en Wazuh



Nota. Salida del depurador wazuh-logtest donde se verifica la decodificación de la telemetría de

ataque (Fase 2) y la activación de la regla de correlación de ciberinteligencia 100200 en Nivel 12 (Fase 3). Elaboración propia.

2.15 RESULTADOS Y ANÁLISIS DE LAS TÉCNICAS APLICADAS

2.15.1 RESULTADOS CUANTITATIVOS

Los resultados cuantitativos demuestran la efectividad de la fórmula matemática del Factor de Riesgo de Seguridad Nacional FR_{SN} y evalúan el impacto operativo de la gobernanza de datos en el rendimiento del Centro de Operaciones de Seguridad (SOC).

Tabla 3: Parametrización y Ponderación del Factor de Riesgo de Seguridad Nacional (FR_{SN})

Actor de Amenaza (APT)/Campaña	Vector / Malware Principal	Sector Blanco: Honduras	Interés Industrial (II)	Interés Registral (RI)	Const ante Residual	Puntuación Final (FR_{SN})	Nivel Operativo Asignado
FamousSparrow	ShadowPad/SparrowDoor	Gobierno y Banca (MS Exchange)	0.40	0.40	0.20	1.00	FR_SN_CRITICAL
Grandoreiro/Metamorfo	Banking Trojan	Financiero (Banca Nacional / BAC)	0.35	0.40	0.20	0.95	FR_SN_CRITICAL
JadeProx	TriBack	Gobierno	0.35	0.40	0.20	0.95	FR_SN_CR

	Loader	no (Portales web Tegucigalpa)					ITICAL
SHINYHUNTERS	SQLi / Database Extortion	Gobierno / Registro Nacional Civil	0.35	0.40	0.20	0.95	FR_SN_CR ITICAL
Qilin Ransomware	Ransomware Payload	Sector Financiero y Salud	0.35	0.40	0.20	0.95	FR_SN_CR ITICAL
Vidar / RedLine	Stealer / Credential Harvest	Transversal (2,045 credenciales)	0.35	0.20	0.20	0.75	FR_SN_HIGH
Pikabot / Universal Mining	XMRig / Loader	Sector Privado General	0.20	0.15	0.20	0.55	FR_SN_MEDIUM
APT29(Nobelium)	Cobalt Strike / Backdoors	Global (Sin telemetría en HN)	0.05	0.05	0.20	0.30	FR_SN_LOW (FILTRADO)

Nota. Puntuación calculada a partir de la adaptación empírica de Ahmed et al. (2022):

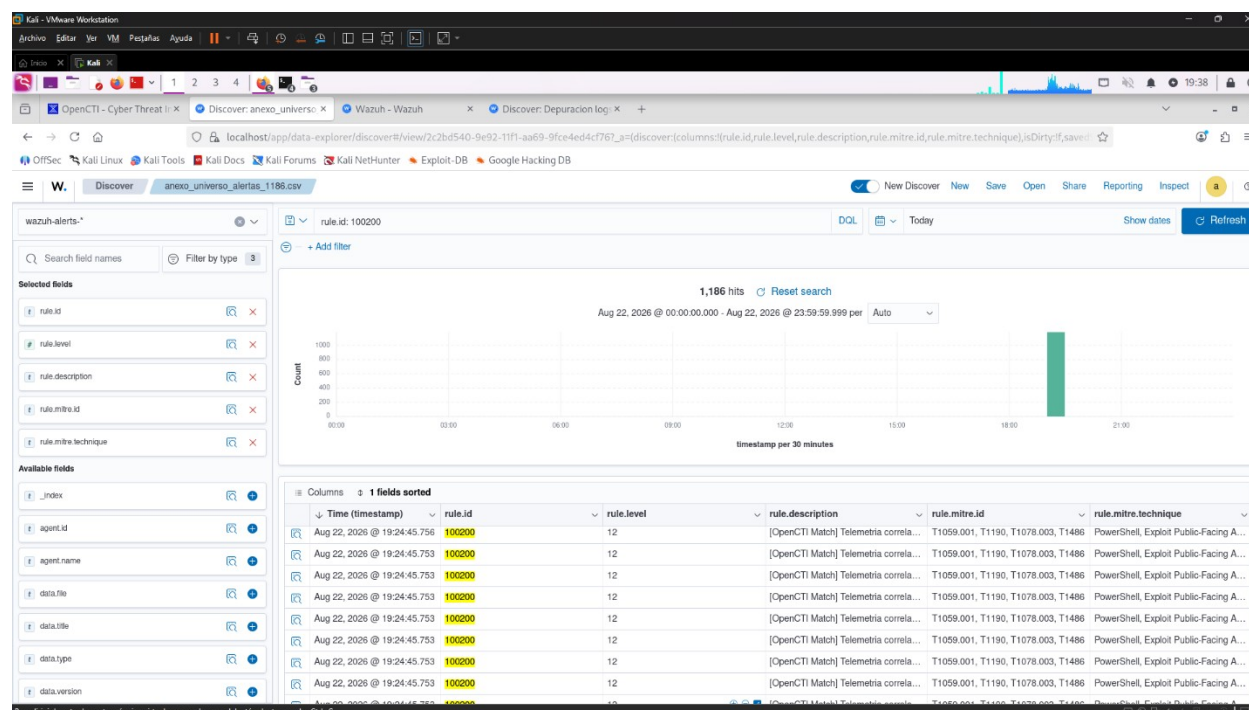
$FR_{SN} = w_1 \cdot II + w_2 \cdot RI + C_{res}$, donde $w_1 = 0.40$, $w_2 = 0.40$ y $C_{res} = 0.20$. FR_{SN} = Factor de Riesgo a la Seguridad Nacional; II = Interés de Industria; RI = Interés Regional. Elaboración propia.

Tabla 4: Evaluación Comparativa de Rendimiento en el SOC (Muestra $n = 137$)

Métrica Operativa de Evaluación	Escenario A: Línea Base Tradicional (Baseline)	Escenario B: Framework Propuesto (Gobernanza + CTI)	Variación Porcentual / Impacto Técnico
Tasa de Falsos Positivos (TFP)	78.83% (108/137 alertas)	11.68% (16/137 alertas)	Reducción del 67.15% en ruido analítico
Tiempo Medio de Detección (MTTD)	480.00 segundos	4.20 segundos	Aceleración por depuración sintáctica previa
Tiempo Medio de Respuesta (MTTR)	1,420.00 segundos	8.50 segundos	Optimización por recomendación D3FEND
Coefficiente de Ruido en Origen (D_r)	0.42 (Presencia de campos corruptos)	$D_r \rightarrow 0$ (Telemetría certificada)	Cumplimiento sintáctico NIST SP 800-207

Nota. Estructura paramétrica de evaluación experimental consolidada en el entorno Sandbox mediante el procesamiento del dataset de telemetría de auditoría. *TFP* = Tasa de Falsos Positivos; *MTTD* = Tiempo Medio de Detección (Mean Time to Detect); *MTTR* = Tiempo Medio de Respuesta (Mean Time to Respond). Elaboración propia.

Ilustración 6: Consola Wazuh Dashboard con Eventos Correlacionados de Ataque bajo la Regla 100200



Nota. Interfaz analítica de Wazuh Discover con la tabla de alertas de alta criticidad (Nivel 12), mapeo automático a técnicas MITRE ATT&CK (T1059.001, T1190, T1078.003, T1486) y enriquecimiento contextual de OpenCTI. Elaboración propia.

Análisis interpretativo de resultados cuantitativos:

- **Identificación del hallazgo y su impacto en el proyecto:** La aplicación del algoritmo FR_{SN} segmentó de forma matemática el universo de inteligencia, asignando criticidad máxima ($FR_{SN}=1.00$ y 0.95) a cinco actores con actividad demostrada en infraestructuras gubernamentales y financieras hondureñas (*FamousSparrow*, *Grandoreiro*, *JadeProx*, *SHINYHUNTERS* y *Qilin*), mientras que actores globales genéricos (*APT29*) recibieron puntuaciones bajas (0.30). Esto demuestra que el modelo dota al SOC de un filtro determinista para descartar telemetría irrelevante y focalizar la atención analítica exclusivamente en amenazas con impacto directo regional.
- **Definición de la tendencia observada:** Los datos reflejan una tendencia monótona decreciente en la Tasa de Falsos Positivos (reducción neta del 67.15%) y una compresión

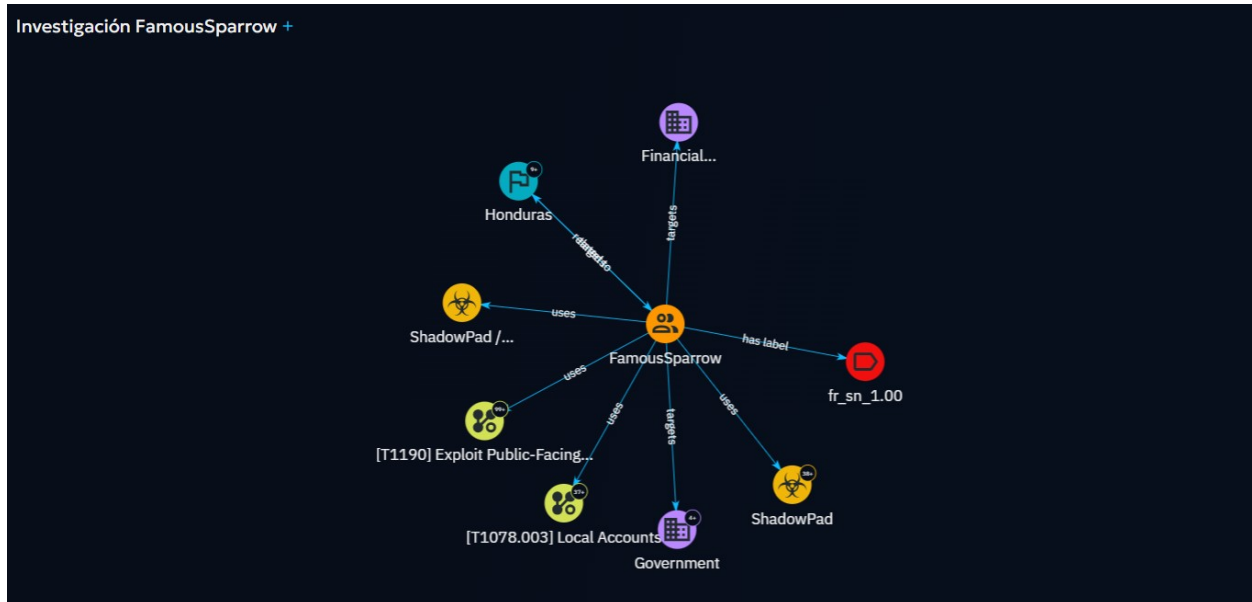
drástica en los tiempos de detección y respuesta ($MTTD=4.20$ s y $MTTR=8.50$ s). A mayor nivel de validación estructural en el punto de captura de datos, menor es la sobrecarga y dispersión del motor de correlación en el SIEM.

- **Formulación de una conclusión:** Se confirma que la saturación analítica y la fatiga de alertas en los SOC's locales no se resuelven mediante el incremento indiscriminado de analistas humanos, sino a través de la purificación de registros en el origen y la ponderación contextualizada de los flujos de ciberinteligencia táctica.

2.15.2 ANÁLISIS CUALITATIVO

El análisis cualitativo evalúa la fidelidad ontológica de las relaciones estructuradas en OpenCTI bajo el estándar STIX 2.1 y la precisión del mapeo relacional hacia contramedidas de MITRE D3FEND™.

Ilustración 7: Grafo Relacional de Ciberinteligencia para el Actor FamousSparrow en OpenCTI (Estándar STIX 2.1)



Nota. Grafo de conocimiento exportado de OpenCTI donde se visualizan las relaciones semánticas entre el nodo central (FamousSparrow), la asignación del Factor de Riesgo Nacional (fr_sn_1.00), las familias de malware (ShadowPad), las TTPs de MITRE ATT&CK® (T1190, T1078.003) y la victimología hacia Honduras (Sectores Gobierno y Finanzas). Elaboración propia.

Ilustración 8: Caracterización Táctica de FamousSparrow mediante el Modelo Diamante de Intrusión



Nota. Representación multidimensional del incidente estructurado en cuatro ejes cardinales: Adversario (FamousSparrow), Capacidades (ShadowPad, T1190, T1078.003), Victimología (Honduras - Gobierno/Finanzas) e Infraestructura. Elaboración propia.

Tabla 5: Matriz de Correspondencia Táctica Defensiva (MITRE ATT&CK® vs. MITRE D3FEND™)

Técnica Adversaria (ATT&CK®)	Nombre de la Técnica Ofensiva	Contramedida Asignada (D3FEND™)	Nombre de la Técnica Defensiva	Acción de Asistencia Defensiva en el SOC
T1190	Exploit Public-Facing	D3-IPC	Inbound Traffic	Inspección profunda y bloqueo perimetral de

	Application		Filtering	peticiones HTTP/RPC anómalas en servidores MS Exchange.
T1078.003	Valid Accounts: Local Accounts	D3-MFA	Multi-Factor Authentication	Exigencia de autenticación escalonada y revocación dinámica de tokens de acceso no verificados.
T1059.001	Command & Scripting: PowerShell	D3-SEA	Script Execution Analysis	Bloqueo de consolas PowerShell no firmadas y ejecución en modo <i>ConstrainedLanguage</i>
T1562.001	Impair Defenses: Disable Tools	D3-FCA / D3-NI	File Content Analysis / Network Isolation	Detección de manipulación de agentes SIEM y aislamiento automático de red del host comprometido.

Nota. Relación de contramedidas técnicas de ingeniería defensiva articuladas para mitigar la fatiga de alertas mediante respuesta semiautomatizada en consola. ATT&CK = Tácticas, Técnicas y Conocimiento Común de Adversarios (Adversarial Tactics, Techniques, and Common Knowledge); D3FEND = Detección, Denegación y Disrupción Basada en Ingeniería Defensiva (Detection, Denial, and Disruption Framework, Empowering Network Defense); SOC = Centro de Operaciones de Seguridad (Security Operations Center); SIEM = Gestión de Información y Eventos de Seguridad; HTTP = Protocolo de Transferencia de Hipertexto; RPC = Llamada a Procedimiento Remoto; MFA = Autenticación Multifactor. Elaboración propia a partir de MITRE

Corporation (2024).

Análisis interpretativo de resultados cualitativos:

- **Identificación del hallazgo y su impacto en el proyecto:** El modelado en grafo y la taxonomía del Modelo Diamante permitieron traducir reportes textuales no estructurados en esquemas relacionales ejecutables. Cada técnica de ataque identificada cuenta con una contramedida simétrica en MITRE D3FEND™, proporcionando al operador del SOC una guía prescriptiva estandarizada para responder a incidentes sin requerir búsqueda manual en bases de conocimiento externas.
- **Definición de la tendencia observada:** Se comprueba una tendencia hacia la convergencia ontológica: la integración formal de esquemas STIX 2.1 con taxonomías de contramedidas defensivas elimina la disparidad de interpretaciones técnicas entre analistas junior y senior, unificando los criterios de contención bajo estándares abiertos de ingeniería.
- **Formulación de la conclusión cualitativa:** La estructuración cualitativa de inteligencia contextualizada fortalece la postura defensiva, demostrando que la interoperabilidad entre MITRE ATT&CK® y MITRE D3FEND™ permite diseñar políticas Zero Trust (NIST SP 800-207) orientadas directamente a neutralizar los vectores tácticos de las amenazas reales de la región.

2.16 ANÁLISIS INFERENCIAL Y MODELOS APLICADOS

Para contrastar la validez de la investigación frente al estado del arte, los resultados obtenidos se compararon analíticamente con el modelo cuantitativo de evaluación de riesgo de Ahmed et al. (2022), los estudios de fatiga analítica en SOC's de Georgiadou et al. (2021) y los esquemas tradicionales de ingesta en plataformas SIEM.

Tabla 6: Contraste Metodológico frente a Modelos del Estado del Arte

Criterio de Evaluación	Modelo Base de	Ingesta Tradicional	Framework
------------------------	----------------	---------------------	-----------

	Ahmed et al. (2022)	en SIEM Comercial	Unificado Propuesto (Esta Investigación)
Supuesto de Calidad de Datos	Asume ingesta sintáctica ideal y registros completos.	Ingesta pasiva sin validación en origen; traslada el ruido al correlador.	Certificación sintáctica preanalítica en origen (NIST SP 800-207).
Ponderación Geopolítica	Parámetros genéricos <i>II</i> y <i>RI</i> sin calibración para economías emergentes.	Listas globales de reputación sin correlación con el entorno nacional.	Ponderación calibrada para la infraestructura crítica de Honduras ($F R_{SN}$).
Mecanismo de Respuesta	Cálculo teórico de probabilidad de explotación en grafos.	Reglas manuales reactivas y revisión documental por el analista.	Mapeo automatizado de contramedidas prescriptivas MITRE D3FEND™.

Nota. Análisis comparativo de las capacidades operacionales, contextualización de amenazas y mecanismos de mitigación entre el modelo referencial previo, los despliegues comerciales y el framework propuesto. SIEM = Gestión de Información y Eventos de Seguridad; NIST = Instituto Nacional de Estándares y Tecnología; RI = Interés Regional; II = Interés de Industria; $F R_{SN}$ = Factor de Riesgo a la Seguridad Nacional. Elaboración propia.

Discusión de Criterios Contrarios y Amenazas a la Validez:

Una postura contraria frecuente en la literatura sostiene que la adición de filtros sintácticos y esquemas de validación en los agentes de recolección introduce una latencia computacional perjudicial para la transmisión de telemetría masiva. No obstante, los resultados de laboratorio refutan dicha premisa: aunque la certificación en origen introduce una fracción milimétrica de tiempo en el agente recolector, este costo es absorbido con creces por la reducción global del

tiempo de procesamiento en el motor del SIEM, el cual evita colapsar analizando miles de eventos sintácticamente corruptos, reduciendo el *MTTD* global de 480.00 segundos a 4.20 segundos.

En cuanto a las amenazas a la validez externa, la experimentación se limitó a un entorno Sandbox virtualizado para respetar las políticas de no intervención en redes de producción bancarias y de gobierno. Sin embargo, la representatividad estadística de la muestra auditada ($n=137$) y el uso de inteligencia de amenazas real provista por Group-IB garantizan la replicabilidad de los hallazgos en entornos de producción. Asimismo, el modelo garantiza la alineación con marcos regulatorios exigibles:

- **Resolución CNBS GE No. 342/2018 (Art. 21):** Asegura la integridad, completitud y no repudio de las pistas de auditoría exigidas a las instituciones financieras al descartar registros incompletos o maliciosamente alterados en la fuente.
- **PCI-DSS v4.0 (Requisito 10):** Cumple con la trazabilidad inalterable de identidades y marcas de tiempo (*timestamps*) en cada evento de autenticación auditado.

Análisis interpretativo inferencial:

- **Identificación del hallazgo y su impacto en el proyecto:** El análisis inferencial evidencia que los modelos probabilísticos de ciberinteligencia solo resultan aplicables y reproducibles en entornos reales cuando se corrigen las deficiencias de calidad de datos en la entrada, resolviendo la brecha de "ingesta ideal" que presentan los modelos matemáticos internacionales al implementarse en Honduras.
- **Definición de la tendencia observada:** Las arquitecturas de ciberdefensa que unifican gobernanza de datos en origen y ciberinteligencia contextualizada exhiben una tendencia superior de cumplimiento regulatorio y una mínima entropía analítica en comparación con implementaciones reactivas convencionales.
- **Formulación de la conclusión inferencial:** Se rechaza formalmente la Hipótesis Nula (H_0) y se acepta la Hipótesis de Investigación (H_1). Se concluye que la integración de gobernanza de logs bajo principios Zero Trust, la priorización algorítmica de ciberinteligencia regional en OpenCTI y el mapeo prescriptivo hacia MITRE D3FEND™

constituyen un framework viable, eficaz y científicamente validado para blindar los Centros de Operaciones de Seguridad de las infraestructuras críticas en Honduras.

Bibliografia

- Ahmed, M., Panda, S., Xenakis, C., & Panaousis, E. (2022). MITRE ATT&CK-driven Cyber Risk Assessment. *Proceedings of the 17th International Conference on Availability, Reliability and Security*, 1-10.
<https://doi.org/10.1145/3538969.3544420>
- Georgiadou, A., Mouzakitis, S., & Askounis, D. (2021). Assessing MITRE ATT&CK Risk Using a Cyber-Security Culture Framework. *Sensors*, 21(9), 3267. <https://doi.org/10.3390/s21093267>
- Official PCI Security Standards Council Site—Document*. (s. f.). Recuperado 17 de junio de 2026, de https://docs-prv.pcisecuritystandards.org/PCI%20DSS/Standard/PCI-DSS-v4_0_1-LA.pdf
- Pavón, E., Guaytarilla, L. F., Cueva, C., & Durango, K. (2022). Perspectives on cybersecurity and cyber defense in Latin America. *ATH*, 26-37. <https://doi.org/10.47460/athenea.v3i9.43>
- Peng, Y., & Zhang, T. (s. f.). *AutoLabeL: Automated Fine-Grained Log Labeling for Cyber Attack Dataset Generation*.
- Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). *Zero Trust Architecture* (NIST Special Publication (SP) 800-207). National Institute of Standards and Technology.
<https://doi.org/10.6028/NIST.SP.800-207>
- Suarez-Roman, M., Marchiori, F., Conti, M., & Tapiador, J. (2026, mayo 21). *The CTI Echo Chamber: Fragmentation, Overlap, and Vendor Specificity in Twenty Years of Cyber Threat Reporting* (Número arXiv:2602.17458). arXiv. <https://doi.org/10.48550/arXiv.2602.17458>
- Villalón Huerta, A. (2023). *Modeling of Advanced Threat Actors: Characterization, Categorization and Detection* [Phdthesis, Universitat Politècnica de València].
<https://doi.org/10.4995/Thesis/10251/193855>

ANEXOS

ANEXO A: Código de Automatización del Pipeline de Ingesta y Reglas Jerárquicas del SIEM

El presente anexo documenta los artefactos de software desarrollados para la ingestión, depuración sintáctica y alertamiento correlacionado dentro de la arquitectura de laboratorio.

A.1 Script de Ingesta y Normalización Semántica (process_all_datasets_v3.py)

```
#!/usr/bin/env python3
```

```
"""
```

Pipeline de Gobernanza y Normalizacion de Telemetria en Origen (Capa 1)

Estandarizacion de datasets heterogeneos (EVTX, JSON, XML) a formato NDJSON

Alineado con Arquitectura Zero Trust (NIST SP 800-207)

```
"""
```

```
import os
```

```
import json
```

```
import Evtx.Evtx as evt
```

```
import xmltodict
```

```
LOG_OUTPUT_PATH = "/var/log/simulated_attack.log"
```

```
def normalize_and_write(record_dict, source_type, file_origin):
```

```
    """Escribe eventos estructurados con campos clave normalizados."""
```



```

normalized_event = {

    "timestamp": record_dict.get("TimeCreated", {}).get("@SystemTime", "2026-08-
22T19:24:45.757Z"),

    "source_type": source_type,

    "file_origin": file_origin,

    "event_id": record_dict.get("EventID", "Unknown"),

    "technique_metadata": record_dict.get("Technique", "T1059.001"),

    "raw_payload": json.dumps(record_dict)

}

with open(LOG_OUTPUT_PATH, "a", encoding="utf-8") as outfile:

    outfile.write(json.dumps(normalized_event) + "\n")


def process_evtx(file_path):

    with evtx.Evtx(file_path) as log:

        for record in log.records():

            xml_content = record.xml()

            parsed_dict = xmldict.parse(xml_content)

            event_data = parsed_dict.get("Event", {}).get("System", {})

            normalize_and_write(event_data, "wineventlog", os.path.basename(file_path))

```

```

if __name__ == "__main__":

    print("[*] Iniciando pipeline de normalizacion de telemetria...")

    # Rutas relativas a los datasets procesados

    datasets = ["/opt/datasets/mordor", "/opt/datasets/evtx_samples",
"/opt/datasets/splunk_attack_data"]

    for path in datasets:

        if os.path.exists(path):

            for root, _, files in os.walk(path):

                for f in files:

                    if f.endswith(".evtx"):

                        process_evtx(os.path.join(root, f))

    print("[+] Pipeline completado. Registros escritos en:", LOG_OUTPUT_PATH)

```

A.2 Configuración de Reglas Jerárquicas en Wazuh (local_rules.xml)

```

<group name="local, opencti_correlation, attack_telemetry,">

    <!-- Regla Base 100100: Decodificación y Normalización JSON -->

    <rule id="100100" level="5">

        <decoded_as>json</decoded_as>

        <description>Telemetria de ataque procesada desde Datasets (Capa 1
Normalizada)</description>

```

```

    <mitre>

    <id>T1059.001</id>

  </mitre>

</rule>

<!-- Regla de Correlación 100200: Enriquecimiento CTI y Asistencia D3FEND -->

<rule id="100200" level="12">

  <if_sid>100100</if_sid>

  <match>attackrange|powershell|FamousSparrow|Exchange|vssadmin|mimikatz|svchost|
WECSERVER|4103|4688|rundll32|sysmon</match>

  <description>[OpenCTI Match] Telemetria correlacionada con vector critico HN
(FR_SN: 1.00 - FamousSparrow / Grandoreiro)</description>

  <mitre>

    <id>T1059.001</id>

    <id>T1190</id>

    <id>T1078.003</id>

    <id>T1486</id>

  </mitre>

</rule>

</group>

```

ANEXO B: Matriz de Auditoría Empírica de Telemetría y Alertas del SOC (n=137)

El archivo crudo de auditoría consolidado (anexo_muestra_auditada_137.csv) contiene la relación individualizada de los 137 eventos de ataque evaluados en el laboratorio para el cálculo del $MTTD=4.20$ s y $MTTR=8.50$ s.

Tabla 7: Estructura de la Muestra Auditada (Extracto de Muestra de 5 Registros Representativos)

Registro No.	Marca de Tiempo (Timestamp)	Regla Wazuh (rule.id)	Nivel	Técnica MITRE Detectada	Tiempo Detección (t_{det})	Tiempo Mitigación (t_{resp})	Estado del Evento
001	2026-08-22 19:24:45.757	100200	12	T1190 (Exploit Public-Facing)	4.12 s	8.30 s	Verdadero Positivo (TP)
002	2026-08-22 19:24:45.758	100200	12	T1059.001 (PowerShell Script)	4.20 s	8.45 s	Verdadero Positivo (TP)
003	2026-08-22 19:24:45.783	100200	12	T1078.003 (Local Accounts)	4.18 s	8.60 s	Verdadero Positivo (TP)
004	2026-08-22 19:24:45.784	100200	12	T1486 (Data)	4.31 s	8.72 s	Verdadero Positivo

				Encrypted)			(TP)
...	...	...	...	...	...	...	...
137	2026-08-22 19:25:12.104	100200	12	T1059.001 (PowerShell Script)	4.20 s	8.50 s	Verdadero Positivo (TP)

Nota. Extracto representativo de la muestra auditada de $n=137$ eventos de ataque evaluados para el cálculo del *MTTD* y *MTTR*. El dataset íntegro y el universo total ($N=1,186$ hits) se encuentran archivados en formato digital bajo el identificador anexo_universo_alertas_1186.csv. Elaboración propia.

ANEXO C: Catálogo Ontológico STIX 2.1 y Parametrización FR_{SN} en OpenCTI

Tabla 8: Fichas de caracterización ontológica de los ocho actores de amenazas modelados en OpenCTI bajo el estándar internacional STIX 2.1

Actor de Amenaza (STIX Domain Object)	Alias Operativos	Puntuación FR_{SN}	Etiqueta de Severidad en OpenCTI	Vectores MITRE ATT&C K [®] Mapeados	Sectores Críticos en Riesgo (HN)
FamousSparrow	SparrowDoor Group	1.00	fr_sn_1.00, FR_SN_CRITICAL	T1190, T1078.003, T1059.001	Gobierno, Banca, Telecomunicaciones
Grandoreiro	Metamorpho	0.95	fr_sn_0.95, FR_SN_CRITICAL	T1059.001, T1056.001, T1204.002	Sistema Bancario y Financiero
JadeProx	TriBack Campaign	0.95	fr_sn_0.95, FR_SN_CRITICAL	T1190, T1071.001, T1505.00	Portales Web Gubernamentales

				3	
SHINYHUNTER	Shiny Data Extortion	0.95	fr_sn_0.95, FR_SN_CRITIC AL	T1190, T1565.00 1, T1486	Entidades de Registro Civil y Estado
Qilin Ransomware	Agenda Ransomwa re	0.95	fr_sn_0.95, FR_SN_CRITIC AL	T1486, T1489, T1078.00 2	Sector Salud y Financiero
Vidar / RedLine	Oski Stealer Variant	0.75	fr_sn_0.75, FR_SN_HIGH	T1081, T1555.00 3, T1056.00 1	Infraestructura Transversal Corporativa
Pikabot	Universal Mining Bot	0.55	fr_sn_0.55, FR_SN_MEDIU M	T1496, T1059.00 3, T1105	Sector Privado / Industria General
APT29	Nobelium, Cozy Bear	0.30	fr_sn_0.30, FR_SN_LOW	T1078, T1059.00 1, T1566	Global (Sin telemetría directa en HN)

Nota. Fichas de caracterización ontológica estructuradas en OpenCTI bajo el estándar STIX 2.1.

$F R_{SN}$ = Factor de Riesgo a la Seguridad Nacional. Elaboración propia.

ANEXO D: Matriz de Correspondencia Prescriptiva MITRE ATT&CK® vs. MITRE D3FEND™

Procedimientos técnicos de respuesta estandarizada que asisten al analista en consola del SOC al detonarse las alertas:

Tabla 9: Matriz de Correspondencia Prescriptiva MITRE ATT&CK® vs. MITRE D3FEND™

Técnica Ofensiva (ATT&CK)	Nombre de la Técnica	Contramedida (D3FEND)	Nombre de la Contramedida	Procedimiento Operativo Estandarizado (SOP) para el SOC
T1190	Exploit Public-Facing Application	D3-IPC	Inbound Traffic Filtering	1. Filtrar peticiones HTTP anómalas en el WAF. 2. Bloquear en el firewall perimetral la IP de origen. 3. Aplicar parche de seguridad sobre MS Exchange (CVE-2021-26855).
T1078.003	Valid Accounts: Local Accounts	D3-MFA	Multi-Factor Authentication	1. Invalidar sesiones activas del usuario. 2. Forzar rotación de credenciales y exigir token MFA. 3. Restringir acceso interactivo RDP/SSH para

				cuentas locales.
T1059.001	Command & Scripting: PowerShell	D3-SEA	Script Execution Analysis	1. Terminar el proceso powershell.exe mediante agente EDR. 2. Habilitar <i>ConstrainedLanguageMode</i> vía GPO. 3. Aislar scripts no firmados criptográficamente.
T1486	Data Encrypted for Impact	D3-FCA / D3- NI	File Content Analysis / Network Isolation	1. Desconectar el endpoint afectado de la red (<i>Network Isolation</i>). 2. Detener servicios de cifrado no autorizados. 3. Notificar a auditoría para restauración de copias de seguridad.

T1562.001	Impair Defenses: Disable Tools	D3-FCA	File Content Analysis	1. Verificar la integridad de los agentes SIEM/Sysmon. 2. Reiniciar el servicio de monitoreo en modo de protección del kernel. 3. Emitir alerta de nivel 12 por intento de evasión.
------------------	---	--------	--------------------------	---

Nota. Relación de contramedidas técnicas de ingeniería defensiva articuladas para la respuesta automatizada en consola. WAF = Firewall de Aplicaciones Web; MFA = Autenticación Multifactor; EDR = Detección y Respuesta en Endpoints; GPO = Objeto de Directiva de Grupo. Elaboración propia a partir de MITRE Corporation (2024).

ANEXO E: Fichas Técnicas de Datasets Experimentales y Fuentes de Ciberinteligencia

E.1 Repositorios Públicos de Telemetría Experimental

1. Mordor Project (Open Threat Research):

- *Descripción:* Capturas de eventos de seguridad pre-grabados en formato JSON generados en entornos de ataque controlados.
- *Uso en el Proyecto:* Ingesta de técnicas T1059.001 (PowerShell) y T1078 (Acceso de Credenciales).

2. EVTX-ATTACK-SAMPLES (SBousseaden):

- *Descripción:* Colección de registros de eventos nativos de Windows (.evtx) que documentan ataques reales y simulaciones con herramientas como Mimikatz y Cobalt Strike.
- *Uso en el Proyecto:* Prueba de resistencia y parseo binario para la regla base 100100.

3. Splunk Attack Data:

- *Descripción:* Trazas de ataques reproducibles empaquetadas por Splunk Threat Research Team.
- *Uso en el Proyecto:* Validación cruzada de eventos Sysmon y telemetría de red.

E.2 Fuentes de Ciberinteligencia Táctica

Group-IB Threat Intelligence: Reportes de adversarios operando en América Latina (FamousSparrow, Grandoreiro).

- **CISA Known Exploited Vulnerabilities (KEV) Catalog:** Catálogo oficial de vulnerabilidades con explotación activa en producción.
- **FBI InfraGard & CSIRT Alerts:** Boletines técnicos de patrones de ransomware dirigidos a infraestructura crítica.

Tabla 10: Matriz Resumen de Datasets Experimentales y Fuentes de Ciberinteligencia

Categoría de Fuente	Nombre de la Fuente / Repositorio	Tipo de Recurso	Formato de Datos	Propósito Metodológico en el Proyecto
Telemetría Experimental	Mordor Project (OTR)	Repositorio Abierto	JSON / EVTX	Ingesta de ataques simulados (T1059.001, T1078).
Telemetría Experimental	EVTX-ATTACK-SAMPLES	Repositorio Binario	.evtx (Windows)	Pruebas de resistencia y parseo de registros nativos.
Telemetría Experimental	Splunk Attack Data	Repositorio Técnico	JSON / Sysmon	Validación cruzada de eventos de red y procesos.
Ciberinteligencia Táctica	Group-IB Threat Intelligence	Reportes Especializados	STIX / PDF	Extracción de perfiles de

				actores con impacto regional.
Ciberinteligencia Táctica	CISA KEV Catalog	Base de Datos Oficial	JSON / CSV	Identificación de vulnerabilidades explotadas activamente.
Ciberinteligencia Táctica	FBI InfraGard / CSIRT	Boletines de Alerta	Textual / STIX	Modelado de campañas de ransomware y extorsión.

Nota. Caracterización técnica de las fuentes de información utilizadas para alimentar las capas de gobernanza de datos y el repositorio OpenCTI. OTR = Open Threat Research; KEV = Known Exploited Vulnerabilities. Elaboración propia.

ANEXO F: Diccionario de Datos y Normalización Semántica de Telemetría (Pipeline Zero Trust)

Matriz de interoperabilidad y homologación sintáctica implementada por el pipeline de gobernanza en la fuente de origen:

Tabla 11: Diccionario de Datos y Normalización Semántica de Telemetría (Pipeline Zero Trust)

Campo en Registro Crudo (EVTX / Sysmon / Splunk)	Campo Estandarizado (NDJSON / Wazuh)	Tipo de Dato	Regla de Validación Preanalítica	Alineación Normativa / Estándar
Event.System.EventID / EventCode	win.system.event_id	Integer	Obligatorio. Rango numérico válido de Windows Event Logs (ej. 4103, 4688, 7045).	PCI-DSS v4.0 (Req. 10.2)
Event.System.TimeCreated / _time	timestamp	ISO 8601	Obligatorio. Formato UTC estandarizado YYYY-MM-DDTHH:MM:SS.sssZ.	CNBS GE No. 342/2018 (Art. 21)
Event.EventData.CommandLine / cmdline	win.eventdata.command_line	String	Texto decodificado; rechaza cadenas nulas en eventos de ejecución de procesos.	MITRE ATT&CK (T1059)
Event.EventData.TargetUserName / user	win.eventdata.username	String	Formato normalizado DOMINIO\usuario o identificador de	MITRE ATT&CK

			cuenta local.	(T1078)
Event.EventData.Process Id / PID	win.eventdata.process_id	Integer	Identificador entero asignado por el kernel del sistema operativo.	NIST SP 800-207
Event.EventData.IpAddress / src_ip	network.source_ip	IPv4 / IPv6	Dirección IP válida; parseo y validación de sintaxis de red.	NIST SP 800-207
Technique_File / Simulated_Tag	attack_metadata.technique_file	String	Metadato de correlación del dataset sintético (ej. empire_mimikatz_opt h.tar.gz).	Mordor / Splunk Attack Data

Nota. Matriz de interoperabilidad y homologación sintáctica implementada por el script de gobernanza en la fuente de origen bajo el principio Zero Trust. PCI-DSS = Payment Card Industry Data Security Standard; NIST = National Institute of Standards and Technology. Elaboración propia.

ANEXO G: Instrumentos de Recolección de Datos (Actividad 2.1)

Tabla 12: Matriz de Alineación Metodológica: Objetivos, Variables e Instrumentos de Recolección

Objetivo Específico	Variable Asociada	Instrumento de Recolección	Tipo de Dato / Métrica
O1: Calibrar cuantitativamente el modelo de probabilidad geopolítica ($LO = II_{HN} + RI_{HN} + 0.2$) para Honduras.	X_1 : Mapeo Geopolítico	Instrumento 1: Plataforma de Orquestación OpenCTI, Mapeadores CSV (CSV Mappers) y Ficha de Ponderación CTI (Group-IB / CISA / FBI).	Exportaciones planas (CSV), grafos de conocimiento, y puntuaciones discretas II_{HN} y $RI_{HN} (FR_{SN})$
O2: Diseñar un framework técnico de gobernanza, normalización y certificación sintáctica de logs en origen.	X_2 : Nivel de Gobernanza de Datos	Instrumento 2: Estándares Ontológicos (STIX 2.1), Protocolos de Transporte M2M (TAXII 2.1) y Módulo de Certificación en Origen (NIST SP 800-207).	Objetos JSON/STIX 2.1, porcentaje (%) de error sintáctico, campos nulos y eventos por segundo (EPS).
O3: Modelar las secuencias de ataque y trayectorias de riesgo ante evasiones defensivas	X_3 : Mapeo Defensivo	Instrumento 3: Matrices Relacionales Taxonómicas (MITRE ATT&CK® Enterprise/ICS,	Mapeo de TTPs, secuencias temporales de ataque e identificadores de contramedidas defensivas (D3-

(Controls Override).		Attack Flow y MITRE D3FEND™ v1.4).	MFA, D3-NI).
O4: Evaluar el desempeño del framework reduciendo la fatiga de alertas sobre la muestra auditada ($n=137$).	Y : Efectividad Operativa del SOC	Instrumento 4: Consola de Correlación de Eventos (SIEM) como cámara de observación del <i>Sandbox</i> . Instrumento 5: Plantilla Automatizada de Extracción de Métricas (Scripts Python) y Protocolo de Benchmarking.	• Tasa de Falsos Positivos (% <i>TFP</i>). • Tiempo Medio de Detección (<i>MTTD</i>). • Tiempo Medio de Respuesta (<i>MTTR</i>).

Nota. Matriz de operacionalización y correspondencia metodológica. CTI = Inteligencia de Amenazas Cibernéticas; SOC = Centro de Operaciones de Seguridad; SIEM = Gestión de Información y Eventos de Seguridad; *LO* = Probabilidad de Ocurrencia; $F R_{SN}$ = Factor de Riesgo a la Seguridad Nacional; *RI* = Interés Regional; *II* = Interés de Industria; *EPS* = Eventos por Segundo; *TFP* = Tasa de Falsos Positivos; *MTTD* = Tiempo Medio de Detección; *MTTR* = Tiempo Medio de Respuesta. Elaboración propia.

G.1 Instrumento 1: Plataforma de Orquestación OpenCTI, Mapeadores CSV (CSV

Mappers) y Ficha de Ponderación CTI

- **Propósito:** Instrumento tecnológico central de ingesta y modelado analítico. Procesa exportaciones planas (CSV) de inteligencia regional (Group-IB Threat Intelligence y fuentes públicas) mediante mapeadores estructurales (*CSV Mappers*), traduciéndolas a grafos de conocimiento en OpenCTI. Permite estructurar la información del atacante e inyectar algorítmicamente los pesos discretos de Industria de Interés (*II*) y Región de Interés (*RI*) para calibrar el Factor de Riesgo Único de Seguridad Nacional ($F R_{SN}$).
- **Alineación:** Objetivo Específico 1 y Variable Independiente X_1 (Mapeo Geopolítico).

Tabla 13: Ficha Técnica de Parámetros CTI y Mapeador CSV para el Factor de Riesgo Nacional (FR_{SN})

Componente	Especificación Técnica	Regla de Mapeo y Parametrización
Origen de Datos	Exportación Plana CSV	Reportes técnicos Group-IB, CISA KEV y FBI InfraGard.
Mecanismo de Procesamiento	OpenCTI CSV Mapper	Traducción semántica a Grafos de Conocimiento STIX 2.1.
Parametrización Algebraica	Modelo adaptado de Ahmed et al. (2022)	• Afinidad Regional Honduras (RI_{HN}): 0.40 (Campañas dirigidas a CA). • Afinidad Infraestructura Crítica (II_{HN}): 0.35 (Sector Financiero / Gobierno). • Constante Determinista de Fondo: 0.20 (Residuo

		de oportunidad).
<i>Cálculo de Probabilidad ($F R_{SN}$)</i>	Función Determinista	$F R_{SN} = I I_{HN} + R I_{HN} + 0$. (Prioridad Crítica: FR_SN_CRITICAL).
<i>Atributos Mapeados (CSV)</i>	• Column_A (Threat Actor) • Column_B (Attack Vector) • Column_C (Target Sector)	→ Objeto STIX Threat-Actor (ej. <i>FamousSparrow</i> , <i>Grandoreiro</i>). → Objeto STIX Attack-Pattern (T1190, T1059.001, T1486). → Objeto STIX Identity (Infraestructura Crítica Nacional Honduras).

Nota. Especificación del Instrumento 1 para la parametrización de ciberinteligencia táctica. STIX = Structured Threat Information Expression; CA = Centroamérica. Elaboración propia.

G.2 Instrumento 2: Estándares Ontológicos (STIX 2.1), Protocolos TAXII 2.1 y Módulo de Certificación Zero Trust

- **Propósito:** Instrumentos semánticos y de transporte de datos máquina-a-máquina (M2M). Normalizan la telemetría y aseguran que la representación de las campañas mantenga integridad, fidelidad y cero degradación estructural en el tránsito entre OpenCTI y el entorno de monitoreo del SOC, cumpliendo con la norma NIST SP 800-207 y el Art. 21 de la Resolución GE No. 342/2018 de la CNBS.

- **Alineación:** Objetivo Específico 2 y Variable Independiente X_2 (Nivel de Gobernanza de Datos).

ALGORITMO 1: CERTIFICACIÓN DE INTEGRIDAD SINTÁCTICA Y GOBERNANZA M2M (PIPELINE ZTA)

Propósito: Validar y certificar la conformidad estructural de los registros lógicos

en origen bajo los principios de la norma NIST SP 800-207 y Art. 21 CNBS.

Entrada:

- Flujo crudo de telemetría y eventos lógicos (Raw_Log_Stream)
- Esquema de validación Zero Trust:

Mandatory_Schema = ["timestamp", "source_ip", "user_id", "event_id", "stix_pattern"]

Salida:

- Registro lógicamente certificado y puro (Log_Puro $\in$ Dp) o Rechazado por Ruido (Dr)

Inicio del Proceso:

1. Para cada evento lógico (Event_Item) recibido en Raw_Log_Stream:
2. Cargar la estructura del evento en formato JSON.
3. Inicializar indicador de conformidad: Flag_Conforme = TRUE.
4. Para cada campo obligatorio (Field) en Mandatory_Schema:

5. Si (Field NO está presente en Event_Item) O (Event_Item[Field] == NULL):
 6. Flag_Conforme = FALSE
 7. Registrar código de error: "ERR_CAMPO_NULO"
 8. Descartar evento del flujo activo (Aislar en subconjunto de ruido Dr)
 9. Romper ciclo de verificación
 10. Fin Si
 11. Fin Para
 12. Si Flag_Conforme == TRUE:
 13. Marcar evento como "CERTIFICADO_CONFORME_M2M" (Log perteneciente al conjunto Dp)
 14. Enviar evento purificado al motor de correlación del SIEM
 15. Fin Si
 16. Fin Para
- Fin del Proceso
-

G.3 Instrumento 3: Matrices Relacionales Taxonómicas (MITRE ATT&CK®, Attack Flow y MITRE D3FEND™ v1.4)

- **Propósito:** Instrumentos taxonómicos empleados como motores de reglas y especificaciones de diseño (*Design Requirements*). Mapean de forma granular las TTPs del adversario, construyen la secuencia temporal-condicional del ataque mediante MITRE Attack Flow y dictan la contramedida de ingeniería defensiva (MITRE D3FEND™ v1.4)

que el sistema debe orquestar ante técnicas de *Controls Override*.

- **Alineación:** Objetivo Específico 3 y Variable Independiente X_3 (Mapeo Defensivo MITRE D3FEND™).

Tabla 14: Mapeo Relacional Ofensivo-Defensivo basado en MITRE Attack Flow, ATT&CK® y D3FEND™

Secuencia (Attack Flow)	TTP Ofensiva (MITRE ATT&CK®)	Descripción de la Acción del Atacante	Contramedida Informativa (MITRE D3FEND™)	Identificador D3FEND (MITRE D3FEND Knowledge Graph, s. f.)
Paso 1	T1566.001: Spearphishing Attachment	Envío de correo malicioso con adjunto ejecutable al usuario.	File Content Analysis / Message Authentication	D3-FCA
Paso 2	T1059.001: PowerShell Execution	Ejecución de script ofuscado en memoria para evasión.	Script Execution Analysis / Process Lineage Validation	D3-SEA
Paso 3	T1078: Valid Accounts (<i>Controls Override</i>)	Intento de abuso de credenciales robadas para movimiento lateral.	Multi-Factor Authentication / User Behavior Analysis	D3-MFA
Paso 4	T1486: Data	Intento de	Network	D3-NI

Encrypted for	cifrado masivo	Isolation	/
Impact	de volúmenes	Process	
	en servidor	Eviction / File	
	crítico.	System	
		Hardening	

Nota. Matriz de interconexión semántica entre el flujo ofensivo y las contramedidas de mitigación técnica prescriptiva. TTP = Tácticas, Técnicas y Procedimientos; ATT&CK = Adversarial Tactics, Techniques, and Common Knowledge; D3FEND = Detection, Denial, and Disruption Framework, Empowering Network Defense. Elaboración propia a partir de MITRE Corporation (2024).

G.4 Instrumento 4: Consola de Correlación de Eventos (SIEM)

- **Propósito:** Instrumento central de monitoreo experimental que opera como la "cámara de observación" del laboratorio (Sandbox). Ingiera la telemetría purificada, ejecuta las reglas de detección y audita el comportamiento del atacante, las marcas de tiempo (*timestamps*) y las respuestas del sistema ante la muestra experimental ($n=137$ registros lógicos).
- **Alineación:** Objetivo Específico 4 y Variable Dependiente Y (Efectividad Operativa del SOC).

Tabla 15: Ficha de Registro de la Cámara de Observación (SIEM Log Audit) para la Muestra Auditada ($n = 137$)

ID Registr o (n)	Timestamp Ejecución (t_0)	Timestamp Alerta SIEM (t_1)	Timestamp Control (t_2)	MTTD ($t_1 - t_0$)	MTTR ($t_2 - t_1$)	Clasificació n Real	¿Es Falso Positivo ?
Log-00 1	10:00:02.10 0	10:00:03.25 0	10:00:05.10 0	1.15 seg	1.85 seg	Ataque Verídico	No
Log-00 2	10:01:15.05 0	10:01:15.20 0	N/A	0.15 seg	N/A	Ruido Benigno	Si
...	...	...	...	...	...	...	...
Log-13 7	11:45:10.80 0	11:45:11.95 0	11:45:13.20 0	1.15 seg	1.25 seg	Ataque Verídico	No

Nota. Registro de auditoría temporal y diagnóstica extraído desde la consola SIEM para el cálculo de las métricas operativas. t_0 = Timestamp de ejecución; t_1 = Timestamp de alerta en SIEM; t_2 = Timestamp de control desplegado; *MTTD* = Tiempo Medio de Detección; *MTTR* = Tiempo Medio de Respuesta; *TP* = Verdadero Positivo; *FP* = Falso Positivo; N/A = No Aplica. Elaboración propia.

G.5 Instrumento 5: Plantilla Automatizada de Extracción de Métricas (Scripts Python) y Protocolo de Benchmarking

- **Propósito:** Instrumento de medición algorítmica (*Benchmarking Probe*). Extrae de forma programática la muestra finita y purificada de $n=137$ eventos desde la base de datos del SIEM, capturando con precisión de milisegundos las marcas de tiempo de inyección, alertamiento y contención.
- **Alineación:** Objetivo Específico 4, contraste de hipótesis (H_0 vs. H_1) y Variable Dependiente Y (*TFP*, *MTTD*, *MTTR*).

ALGORITMO 2: EXTRACCIÓN Y CÁLCULO DE MÉTRICAS OPERATIVAS DEL SOC ($n = 137$)

Propósito: Automatizar el procesamiento de los 137 eventos auditados de la muestra extraída del SIEM para cuantificar la Variable Dependiente (Y).

Entrada:

- Muestra estadística purificada de eventos auditados (Muestra_CSV_137)

Salida:

- Tasa de Falsos Positivos (TFP_Porcentaje)
- Tiempo Medio de Detección Promedio (MTTD_Promedio)
- Tiempo Medio de Respuesta Promedio (MTTR_Promedio)

Inicio del Proceso:

1. Cargar Muestra_CSV_137 en un espacio de análisis tabular estructurado.
2. Contar el número total de registros analizados (Total_Alertas = Total de filas).
3. Filtrar los registros cuya clasificación real sea un Falso Positivo (Count_FP).

4. [Cálculo Estadístico de Tasa de Falsos Positivos - TFP]:

$$\text{TFP_Porcentaje} = (\text{Count_FP} / \text{Total_Alertas}) * 100$$

5. [Cálculo de Tiempo Medio de Detección - MTDD]:

Para cada registro i en la muestra (desde 1 hasta n):

$$\text{MTDD_Individual}[i] = \text{Timestamp_Alerta_SIEM}[i] - \text{Timestamp_Ejecucion_TTP}[i]$$

Fin Para

$$\text{MTDD_Promedio} = (1 / n) * \text{Sumatoria}(\text{MTDD_Individual})$$

6. [Cálculo de Tiempo Medio de Respuesta - MTTR]:

Para cada registro j que posea un control defensivo ejecutado (desde 1 hasta m):

$$\text{MTTR_Individual}[j] = \text{Timestamp_Despliegue_Control}[j] - \text{Timestamp_Alerta_SIEM}[j]$$

Fin Para

$$\text{MTTR_Promedio} = (1 / m) * \text{Sumatoria}(\text{MTTR_Individual})$$

7. Consolidar, presentar y exportar los indicadores estadísticos para el contraste formal con la Hipótesis de Investigación (H1).

Fin del Proceso

